

École Centrale des Logiciels Libres et de Télécommunications

Examen
Réagir face à une cyber attaque

Présenté par :

*Mouhamadou Falilou
Sarr*

Widadou Nayil

Francky Fara Mendy

Sous la supervision de :

Mr Fall

Sommaire

I. Définition de quelque terme :.....	3
1.1 Qu'est-ce que l'investigation numérique ?.....	3
1.1.1 L'analyse forensic judiciaire	3
1.1.2 L'analyse forensic en réponse à un incident.....	3
1.1.3 L'analyse forensic scientifique.....	3
II- Les 4 grandes étapes d'une investigation numérique	4
2.1 Étape 1 : Identifiez le contexte et récupérez les informations	4
2.2 Étape 2 : Collectez les supports numériques à analyser	4
2.3 Étape 3 : Analysez les données collectées.....	4
2.4 Étape 4 : Corrélation et reporting	4
III. Les outils nécessaires	5
IV. Analyse de dump mémoire.....	11
V. Récupérez les informations de base du disque pour l'analyse	Erreur ! Signet non défini.

I. Définition de quelque terme :

1.1 Qu'est-ce que l'investigation numérique ?

L'investigation numérique, aussi appelée informatique légale ou forensic numérique, est une discipline qui consiste à identifier, collecter, analyser et préserver des preuves numériques après un incident informatique, comme une attaque, une fraude, un vol de données ou une compromission. Elle permet par exemple de répondre à des questions comme :

- Qui a accédé à telle machine ?
- Quel programme a été lancé ?
- Quelles données ont été volées ?
- Comment l'attaque a-t-elle eu lieu ?

Ainsi, on peut schématiquement diviser l'investigation numérique en trois activités distinctes :

1.1.1 L'analyse forensic judiciaire

Principalement utilisée dans le cadre d'enquêtes judiciaires, elle a pour but de rechercher toutes les preuves numériques (par exemple lors d'une perquisition), afin de collecter et rassembler un maximum de preuves pouvant incriminer ou innocenter le suspect d'une enquête.

1.1.2 L'analyse forensic en réponse à un incident

Elle vise à identifier les **conditions** et les **origines** d'une attaque informatique, quelles sont les machines infectées ou encore par quel **vecteur l'attaque** est survenue. Dans le cas d'une réponse à une intrusion, elle joue le rôle de « pompier » et permet d'identifier rapidement les éléments du système d'information compromis, dans le but de combler les failles et d'éradiquer le ou les malwares.

1.1.3 L'analyse forensic scientifique

Elle consiste à **étudier** les **mécanismes** et les aspects **techniques** d'un malware ou autre logiciel/matériel malveillant, afin d'identifier les méthodes utilisées par les attaquants pour pénétrer et compromettre un réseau informatique. Les analyses sont souvent réalisées dans un **environnement maîtrisé** (appelé *sandbox*).

Windows, première cible des attaques

L'investigation numérique est un domaine vaste et nécessite des années de pratique. Un incident de sécurité peut survenir sur **n'importe quel type de système** : Windows, Linux, Mac, Android, iOS... Il existe des malwares pour toute ces plateformes.

Beaucoup de personne pensent à tort que les **Mac** ne peuvent pas être infectés par un logiciel malveillant. C'est totalement faux ! Ils sont de plus en plus la cible de pirates.

Il existe toutefois une différence notoire : un malware destiné à infecter un système Windows **ne pourra pas infecter un système MacOS**, et vice-versa.

Les systèmes **Windows** sont les **plus répandus en entreprise**, voilà pourquoi ce cours se focalise sur l'investigation sur Windows. Il y a plus de chance que vous soyez confronté à une infection sur un OS Windows que sur Mac, même si ça peut arriver.

Par ailleurs, connaître un système tel que celui de Windows en profondeur nécessite du temps, et étant donné que ce cours ne traite pas en profondeur le système Windows, il aurait été difficile de traiter les autres OS.

II- Les 4 grandes étapes d'une investigation numérique

2.1 Étape 1 : Identifiez le contexte et récupérez les informations

L'**identification du contexte** est une phase très importante, car elle permet d'**obtenir des informations** liées à l'incident de sécurité. Lors de cette phase, vous devrez rencontrer diverses personnes telles que les personnes de l'IT, les **administrateurs**, les **responsables des machines infectées ou encore le RSSI**. Ceci vous permettra d'orienter vos recherches pour ne pas faire fausse route.

2.2 Étape 2 : Collectez les supports numériques à analyser

Vous avez précédemment identifié le **contexte de l'attaque** et également des **machines potentiellement compromises**. La **phase de collecte** va permettre de copier les données pour pouvoir les analyser (copie de la mémoire vive, et copie du disque dur). Vous réaliserez des **hashs** des informations collectées. Cela permettra de réaliser l'analyse sur la copie sans altérer les données originales.

2.3 Étape 3 : Analysez les données collectées

Après avoir collecté les données, il faut maintenant les analyser. C'est la phase la plus technique de l'investigation. Dans cette phase, vous réaliserez la **chronologie** des événements pour extraire la date et le moment précis de l'incident, ainsi que l'analyse des **artefacts** tels que les processus, le registre et le réseau. Une phase de **triage** sera également réalisée.

Nous découperons cette phase en 3 étapes :

1. L'analyse du dump mémoire, c'est-à-dire de la RAM de l'ordinateur
2. L'analyse du disque dur de l'ordinateur et de tous les fichiers qu'il contient.
3. L'analyse des fichiers identifiés comme suspects ou malveillants.

2.4 Étape 4 : Corrélation et reporting

Dans cette phase, vous présenterez dans un **rapport** le résultat de vos analyses. Vous présenterez de manière factuelle les éléments découverts. Vous indiquerez également **les indicateurs de compromission** et les **recommandations** à mettre en place pour améliorer la sécurité de l'entreprise.

Un **indicateur de compromission** est un élément unique et qui permet de caractériser et d'identifier les éléments d'une attaque. Cela peut être :

- Les hash de fichier ou logiciel malveillant ;
- Des adresses IP ;
- Des clés de registre ;
- Des emplacements sur le disque ;
- Une adresse email ;
- Une adresse de portefeuille de cryptomonnaie (pour une rançon, par exemple) ;

- Un mutex.

III. Les outils nécessaires

L'analyse forensic nécessite de respecter des **bonnes pratiques** en utilisant les **outils adéquats**. Il existe une multitude d'outils open source, freeware ou propriétaires, permettant d'analyser des supports numériques. Dans certains cas et notamment lors d'enquêtes judiciaires, il sera également nécessaire d'utiliser du matériel tel que des **bloqueurs en écriture** lors de la collecte de données.

Pour réaliser une analyse forensic de support numérique, il existe sur le marché des outils reconnus.

La société Guidance Software propose une suite d'utilitaires appelée [Encase](#) dédiée à l'analyse forensic, en passant de **l'analyse du disque et au tri des données** jusqu'à **l'analyse des fichiers et le déchiffrement des volumes analysés**. Les licences sont payantes et restent relativement chères. Toutefois, ce genre d'outil est largement utilisé par les experts judiciaires ou encore les organismes de police.

Il existe également des **outils hardware permettant la collecte de supports numériques** sans altération des données, tels que des [bloqueurs en écriture](#) que nous avons évoqués plus haut.

Les bloqueurs en écriture sont donc des dispositifs qui permettent de faire **l'acquisition d'une image d'un disque dur en bloquant le mécanisme d'écriture**, mais pas de lecture, dans le but de préserver le contenu. L'utilisation de ce type de dispositif permet de protéger le contenu du disque et **garantit ainsi son intégrité**.



Un exemple de bloqueur en écriture, connecté à un disque dur pour copier ses données sans qu'elles soient altérées

Un bloqueur en écriture matériel **s'interpose entre le disque dur (la preuve) et le PC** qui servira à l'acquisition de l'image. Il existe également des bloqueurs en écriture **logiciels**.

Il existe également des utilitaires gratuits ou open source qui sont très souvent utilisés lors d'analyses forensic.

Le framework [The Sleuth Kit](#) permet de réaliser une analyse forensic en passant de la **génération d'une timeline au triage des données** et à **l'analyse des artefacts Windows (registre, email, historique...)**, jusqu'à la génération d'un rapport. Il comporte une interface graphique appelée **Autopsy**.

Les utilitaires [NirSoft](#) ou encore la suite [Sysinternal](#) de Microsoft sont également utilisés dans l'analyse forensic. Google a également développé son propre framework d'analyse, [Google Rapid Response](#) (GRR), qui permet de faire de l'analyse forensic à distance de postes compromis.

Certains projets proposent également des **OS Linux destinés à l'analyse forensic** et embarquant des outils préinstallés tels que [SIFT](#), [Tsurugi](#), [CAINE](#) ou encore [DEFT](#).

Pour l'analyse de la **mémoire vive**, il existe également des frameworks tels que [Volatility](#).

Pour la **copie des disques durs et de la RAM**, il est possible d'utiliser le freeware [FTK Imager Lite](#).

1- Contexte

Un utilisateur du **service comptabilité** de votre entreprise a reçu un email contenant une **pièce jointe**. Sans faire attention, l'utilisateur l'a ouverte, pensant qu'elle était légitime. Réalisant son erreur en se rendant compte que l'email émetteur n'était pas légitime, il a directement appelé la direction de la sécurité des systèmes d'information, dont vous faites partie, pour réaliser **l'investigation**.

En tant qu'analyste, nous réaliserons un **dump mémoire** ainsi qu'une **copie bit à bit du disque dur**, pour pouvoir collecter un maximum d'informations. Nous réaliserons une analyse du poste infecté et reporterez l'investigation dans votre **rapport**. Nous identifierons les **IOC (Indicateurs de Compromission)** et proposerez des **plans d'action** pour contenir la menace et l'éradiquer. Enfin, nous proposerons des **recommandations** pour améliorer la sécurité de notre entreprise et la prémunir d'attaques similaires.

2- Préparons notre environnement d'analyse

Nous allons à présent **préparer notre environnement d'analyse**. Nous utiliserons **2 machines virtuelles** pour réaliser les investigations. Cela nous permettra d'appréhender des outils sur les différentes plateformes.

1. Une **VM Windows** sur laquelle il faudra installer les outils The Sleuth Kit Autopsy, FTK Imager et Mft2Csv. nous allons télécharger les différents utilitaires et de les copier dans un répertoire pour les avoir au même endroit. Et nous allons **réaliser un snapshot de vos machines virtuelles** une fois configurées.
2. Une **VM Linux SIFT** que vous pouvez télécharger à [cette adresse](#) (puis suivez les instructions d'installation).

Installation du poste de travail SIFT :

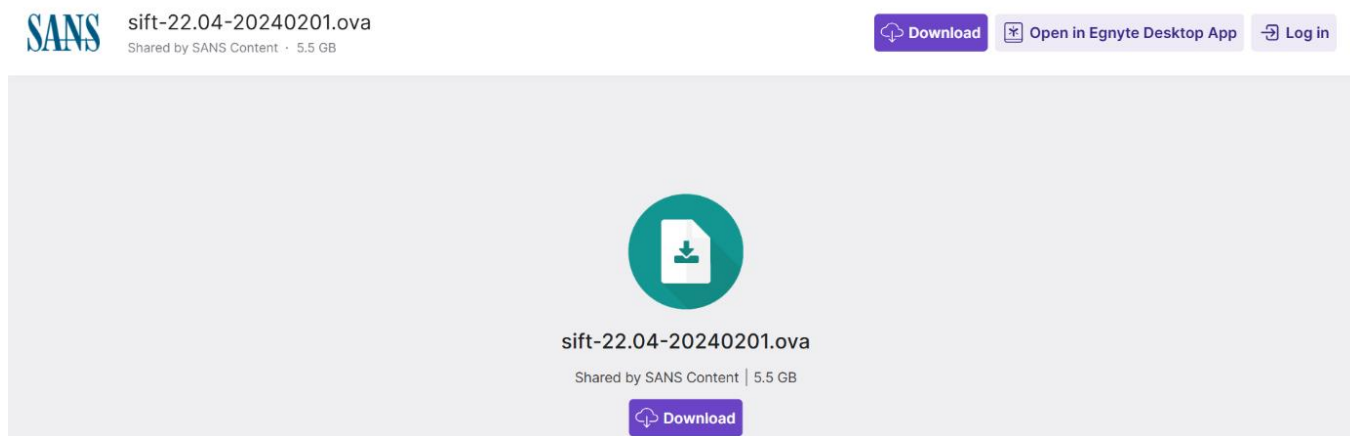
Le SIFT Workstation est une collection d'outils gratuits et open source d'intervention en cas d'incident et d'investigation conçus pour effectuer des examens médico-légaux numériques détaillés dans une variété de contextes. Il peut s'adapter à n'importe quelle suite d'outils de réponse aux incidents et

d'investigation actuelle. SIFT démontre que des capacités avancées de réponse aux incidents et des techniques d'investigation numérique approfondies peuvent être réalisées à l'aide d'outils open source de pointe, disponibles gratuitement et fréquemment mis à jour.

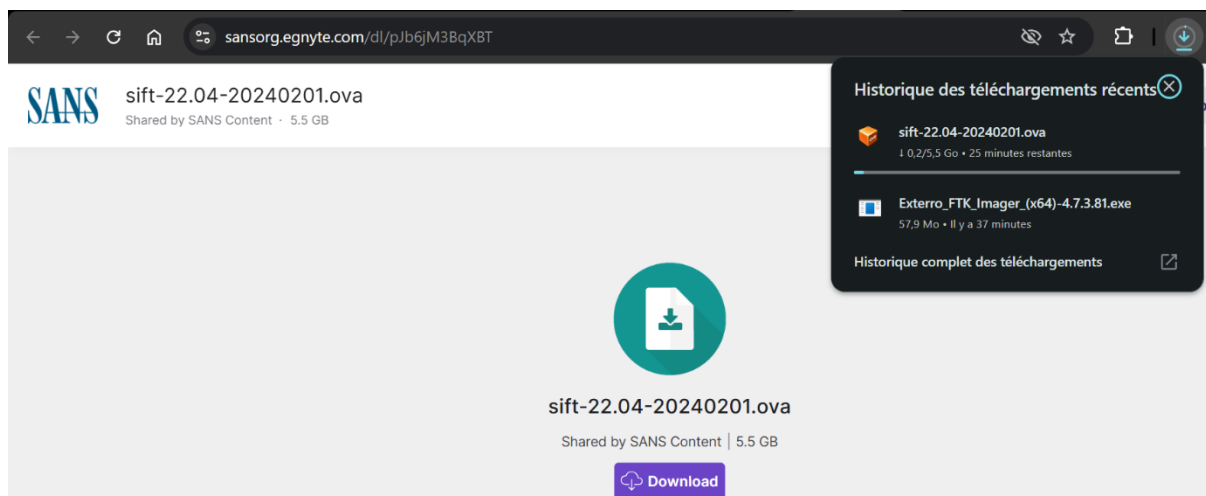
Par Rob Lee

Rendons-nous sur ce lien [Poste de travail SIFT | Institut SANS](#) pour télécharger la VM-SIFT.

Après avoir cliqué sur télécharger, nous aurons la page suivante :



Maintenant cliquons sur **Download** pour obtenir la VM-SIFT et le téléchargement va démarrer comme suit :



Une fois le téléchargement terminé, utiliser notre plateforme de virtualisation VirtualBox pour démarrer la VM-SIFT.

Une fois que nous avons démarré la machine virtuelle, accédons à la VM en utilisant les informations d'identification ci-dessous pour y accéder.

- Login = sansforensics
- Mot de passe = **forensics**
- \$ **sudo su** – (Permet d'élever les privilèges à root lors du montage d'images disque.)

```
sansforensics@siftworkstation: ~  
$ sudo su -  
root@siftworkstation:~#  
root@siftworkstation:~#
```

3- Les formats de collecte de données

La phase de collecte des données, ou encore « l'acquisition », est la phase qui doit permettre de copier les données volatiles et non volatiles sur un support externe, dans le but de réaliser une analyse approfondie par la suite.

Cette phase est très importante, car elle nécessite de respecter une procédure stricte qui **n'altérera pas les données stockées**. Les données collectées seront stockées dans un container que l'on appelle **image**. Une image est un **dump brut extrait d'un support numérique**. Il existe plusieurs formats d'image.

Les images RAW

Les images brutes, au format RAW, ne sont pas un format en soi, mais un **bloc de données brutes** reproduites à partir d'une image. Les images brutes ne contiennent aucune métadonnée supplémentaire en dehors des informations sur le fichier image lui-même (nom, taille, horodatage et autres informations).

Les formats de forensic

Plusieurs problèmes avec les images brutes ont conduit à la création de formats de fichiers pour le forensic. Les formats de forensic comportent des éléments supplémentaires tels que l'horodatage, les hash des images et d'autres **métadonnées**. Par ailleurs, il peut être nécessaire de compresser ou chiffrer une image acquise. Les formats de forensic facilitent la mise en œuvre de ces fonctionnalités. Vous retrouverez entre autres :

- **EnCase EWF**, développé par Guidance Software, l'une des plus anciennes **entreprises de logiciels de forensic**. Il utilise le format EWF (*Expert Witness Format*) qui prend en charge les métadonnées, la compression, le chiffrement, le hachage, etc. ;
- **FTK Smart**, par AccessData, est un concurrent direct d'EnCase EWF. Ce **format propriétaire** inclut également les métadonnées, la compression, le chiffrement, le hachage, etc. ;

AFF, pour *Advanced Forensic Format*, a été créé par Simson Garfinkel en tant que **format ouvert**. Il comprend toutes les fonctionnalités attendues et inclut également des fonctionnalités de chiffrement et de signature utilisant des certificats X.509 standard

4- Différence entre mémoire volatile et non volatile

La **mémoire non volatile** est issue d'un support numérique qui conserve les données présentes même lorsqu'il n'est pas alimenté électriquement — typiquement, un disque dur ou une clé USB.

Ce type de mémoire autorise l'analyse dite à **froid**, ou post mortem, c'est-à-dire après l'incident et une fois que le système a été éteint.

La **mémoire volatile**, elle, est une mémoire informatique qui a **besoin d'alimentation électrique continue pour conserver l'information** qui y est enregistrée. Lorsque l'alimentation électrique est interrompue, l'information contenue dans la mémoire volatile est, quasi immédiatement, perdue. Dans notre cas, on parle de la **RAM**, ou de la **mémoire vive**.

Ce type de mémoire doit obligatoirement être enregistré (dumpé) sur un support externe à **chaud**, c'est-à-dire avant extinction de l'ordinateur, sinon tout sera perdu. Sans ça, vous ne pourrez pas l'analyser pour mener votre investigation.

La mémoire vive d'un ordinateur peut contenir de nombreuses informations : **mots de passe, identifiants, clefs de chiffrement ou encore processus actifs**. Elle est donc très utile pour l'analyse forensic.

5- Réalisation un dump mémoire et une copie bit à bit d'un disque dur

Dans le processus de forensic, il faut dans un premier temps **collecter les données qui seront analysées** par la suite. Dans la réalité, il se peut que vous ayez accès à la machine en cours de fonctionnement ; dans ce cas il faudra réaliser dans un premier temps un **dump de la RAM** pour collecter un instantané des processus en cours d'exécution. Cela vous permettra d'identifier un processus malveillant, par exemple.

Puis il faudra par la suite réaliser la copie bit à bit du disque dur, c'est-à-dire une **copie fidèle de chaque bit du disque**. Cela vous permettra d'accéder à toutes les données du disque pour réaliser l'analyse.

Chaque cas est différent, il se peut que les copies soient déjà réalisées, ou alors que l'on vous transmette uniquement le disque dur. C'est à vous de vous adapter à la situation pour réaliser au mieux l'analyse.



Acquisition de la mémoire volatile

L'acquisition de la mémoire vive intervient généralement lors d'une réponse à incident et **sur un système en fonctionnement**. Lors de l'acquisition, l'analyste **doit éviter au maximum toutes modifications, afin de récupérer une image fidèle du système à analyser**.

Il existe une multitude d'outils pour dumper le contenu de la RAM. Nous allons ici utiliser le logiciel [free FTK imager, téléchargeable à cette adresse](#). Libre à vous d'utiliser un autre outil ; par exemple, l'utilitaire free **Dumpit** est une référence dans l'acquisition de la mémoire volatile.

Avec le logiciel FTK, il suffit de **cliquer sur l'icône RAM** pour réaliser la capture.

Il faudra ensuite préciser le répertoire où le dump sera stocké, puis cliquer sur *Capture Memory* ; il est également possible d'inclure le fichier système pagefile.sys à la copie.

La copie du dump est ensuite réalisée et stockée dans le répertoire mentionné.

Mise en œuvre de l'acquisition de la mémoire volatile

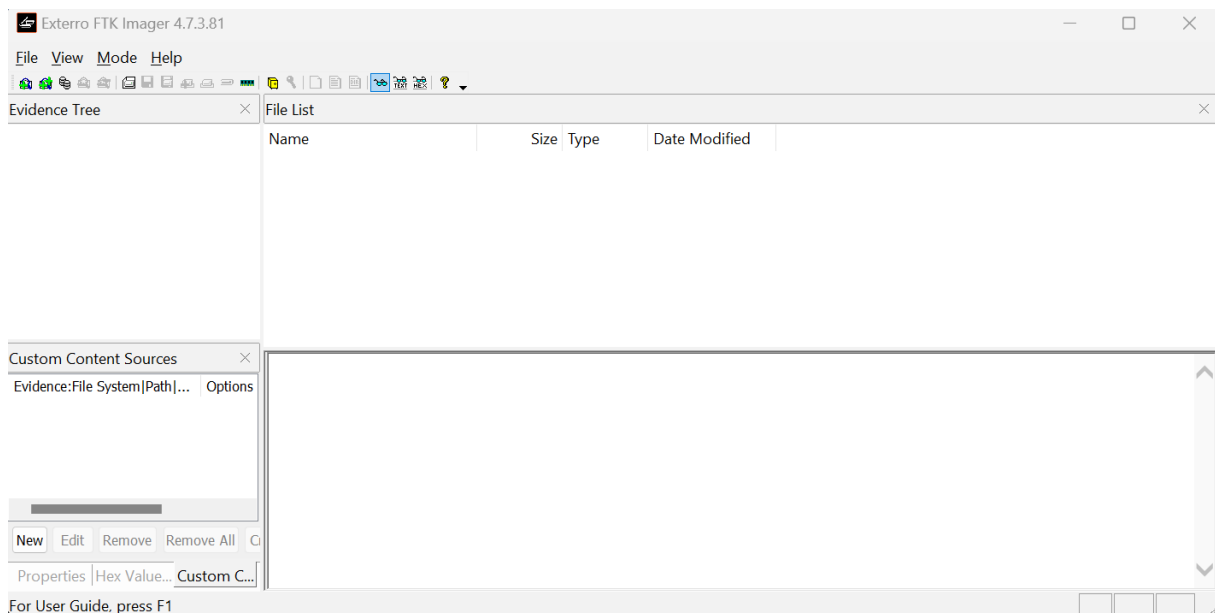
Telechargeons FTK imager :

exterro

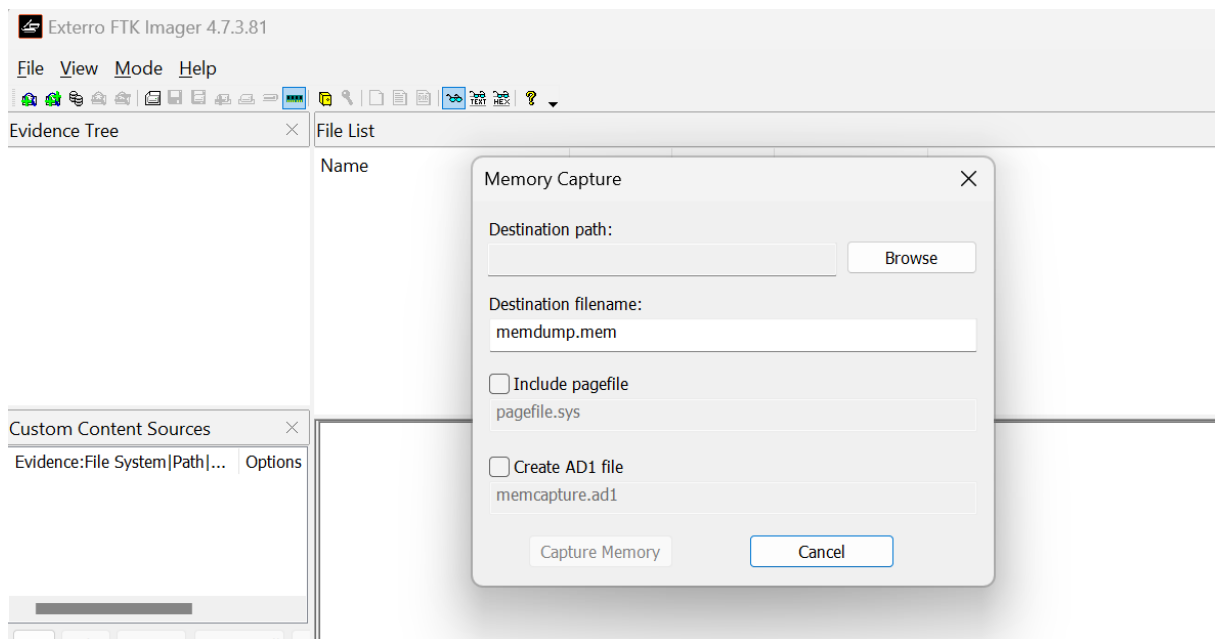
Product Downloads

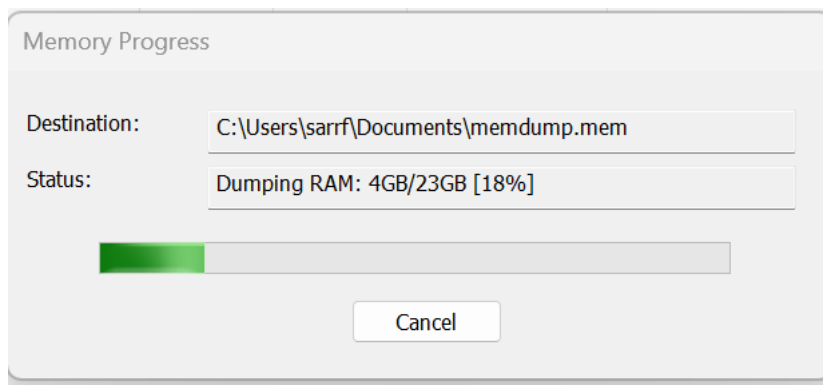
📄 FTK IMAGER 4.7.3.81

Lançons FTK imager :



Une fois lancée on clique *capture memory* comme suit :





Acquisition de la mémoire non volatile

Comme pour la mémoire volatile, l'acquisition de la mémoire non volatile est une partie très importante de l'investigation numérique ; elle doit respecter une procédure stricte, afin de ne pas altérer le contenu du support.

De nombreux outils ont pour but de copier le contenu d'un disque dur pour l'analyser. **Nous allons ici utiliser le logiciel FTK.**

Pour ce faire, il suffit de cliquer sur l'icône Create Image, puis sélectionner la source de la copie à réaliser, ici le disque dur Physical Drive de notre machine.

S'il existe plusieurs disques durs ou des partitions, il faudra sélectionner celui que l'on souhaite copier, puis cliquer sur Finish.

Il faudra ensuite cliquer sur Add pour sélectionner le **format** de l'image.

Ici nous choisirons le format **Raw**, mais vous pouvez utiliser le format que vous désirez.

Il faudra ensuite spécifier quelques informations qui permettront d'identifier la preuve collectée.

Enfin, il faudra sélectionner le répertoire dans lequel le disque sera copié. Il faudra stocker cette image **sur un support amovible externe suffisamment grand.**

Dans la plupart des cas, les dumps que vous devrez réaliser feront **plusieurs centaines de Go**, il faudra par conséquent utiliser des disques durs externes de **plusieurs téraoctets pour stocker ces données.**

Il faudra ensuite cliquer sur *Start* pour réaliser la copie du disque dur.

Le temps nécessaire à la copie du disque sera fonction de la taille du disque.

IV. Analyse de dump mémoire

1- Récupérez les informations importantes de la mémoire Windows pour l'analyse

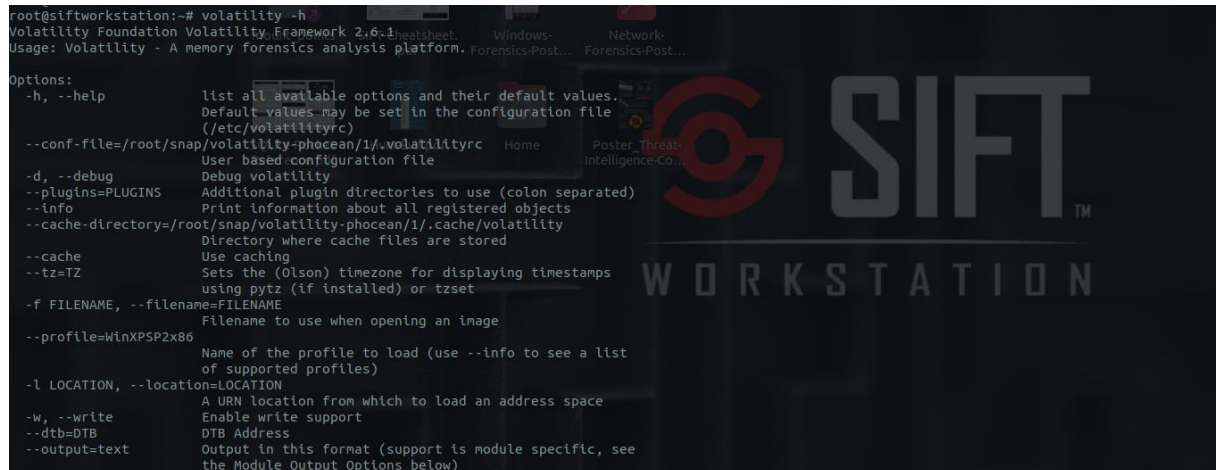
Pour extraire ces informations sur le dump mémoire que nous avons réalisé, nous utiliserons le **framework open source Volatility.**

Prenez en main Volatility

Volatility peut être téléchargé sur le site de [Volatility Foundation](http://www.volatilityfoundation.org). Il existe une version pour Windows, Mac et Linux. Dans votre machine d'analyse SIFT, Volatility est préinstallé !

Pour lancer Volatility, il suffit d'ouvrir un terminal et d'entrer par exemple la commande **volatility -h** pour afficher les **options disponibles** (le retour de cette commande est très long, en voici le début).

```
# volatility -h
```



```
root@siftworkstation:~# volatility -h
Volatility Foundation Volatility Framework 2.6.1
Usage: Volatility - A memory forensics analysis platform.

Options:
  -h, --help                list all available options and their default values.
                           Default values may be set in the configuration file
                           (/etc/volatilityrc)
  --conf-file=/root/.snap/volatility-phocan/1/.volatilityrc  User based configuration file
  -d, --debug                Debug volatility
  --plugins=PLUGINS          Additional plugin directories to use (colon separated)
  --info                     Print information about all registered objects
  --cache-directory=/root/.snap/volatility-phocan/1/.cache/volatility  Directory where cache files are stored
  --cache                    Use caching
  --tz=TZ                    Sets the (Olson) timezone for displaying timestamps
                           using pytz (if installed) or tzset
  -f FILENAME, --filename=FILENAME  Filename to use when opening an image
  --profile=WinXPSP2x86       Name of the profile to load (use --info to see a list
                           of supported profiles)
  -l LOCATION, --location=LOCATION  A URN location from which to load an address space
  -w, --write                Enable write support
  --dtb=DTB                  DTB Address
  --output=text              Output in this format (support is module specific, see
                           the Module Output Options below)
```

2- Récupérez le profil de l'image avec ImageInfo

La première étape pour pouvoir analyser un dump mémoire est de récupérer les informations de l'image qui permettront à Volatility de correctement **parser** les données, c'est-à-dire déterminer son *profile*.

Parser les données, ça veut dire les lire et les interpréter afin de comprendre ce qu'elles signifient. Selon le type de profil que vous signalez à Volatility, il n'interprétera pas les données de la même manière.

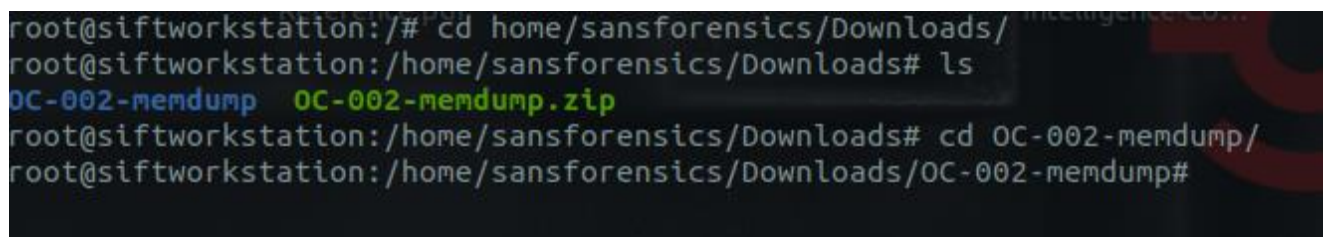
Pour ce faire, nous allons utiliser le fichier memdump.mem peut être obtenu via <http://s3-eu-west-1.amazonaws.com/course.oc-static.com/courses/1750151/OC-002-memdump.zip>

Dans ce contexte, **l'image** dont on parle est **une image mémoire**, c'est-à-dire un **dump de la mémoire vive (RAM)** d'un système au moment où il a été capturé.

Le fichier mentionné ici **memdump.mem** est donc une **copie du contenu de la RAM**, souvent réalisée lors d'une analyse forensique ou d'une investigation en cybersécurité.

Pour cela, nous allons utiliser l'option **ImageInfo** de Volatility sur notre dump mémoire avec la commande **volatility -f memdump.mem imageinfo**.

Accedons au dossier :



```
root@siftworkstation:~/# cd /home/sansforensics/Downloads/
root@siftworkstation:/home/sansforensics/Downloads# ls
OC-002-memdump  OC-002-memdump.zip
root@siftworkstation:/home/sansforensics/Downloads# cd OC-002-memdump/
root@siftworkstation:/home/sansforensics/Downloads/OC-002-memdump#
```

```
$ volatility -f memdump.mem imageinfo
```

```
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$ volatility -f memdump.mem imageinfo
Volatility Foundation Volatility Framework 2.6.1
INFO : volatility.debug : Determining profile based on KDBG search...
      Suggested Profile(s) : Win7SP1x86_23418, Win7SP0x86, Win7SP1x86_24000, Win7SP1x8
6
      AS Layer1 : IA32PagedMemoryPae (Kernel AS)
      AS Layer2 : FileAddressSpace (/home/sansforensics/Downloads/OC-002-me
mdump/memdump.mem)
      PAE type : PAE
      DTB : 0x185000L
      KDBG : 0x82b39c28L
      Number of Processors : 1
      Image Type (Service Pack) : 1
      KPCR for CPU 0 : 0x82b3ac00L
      KUSER_SHARED_DATA : 0xffdf0000L
      Image date and time : 2019-07-31 13:45:40 UTC+0000
      Image local date and time : 2019-07-31 15:45:40 +0200
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$
```

3- Récupérez la liste des processus

L'OS est responsable de **la gestion, de la suspension et de la création de processus**, c'est-à-dire des instances d'un programme.

Lorsqu'un programme s'exécute, un nouveau processus est créé et associé à son propre ensemble d'attributs, y compris un **ID de processus unique (PID)** propre à chacun, et un **espace d'adressage**.

L'espace mémoire d'un processus devient un conteneur pour le code de l'application, les bibliothèques partagées, les données dynamiques et la pile d'exécution.

Un aspect important de l'analyse de la mémoire consiste à **énumérer les processus** qui s'exécutent sur un système et analyser les données stockées dans leur espace d'adressage. L'objectif ? Dénicher les processus correspondant à des programmes potentiellement **malveillants**, ainsi que comprendre **leur fonctionnement, leur origine, et les analyser en détail**.

Pour extraire la liste des processus, il est possible d'utiliser l'option **pslist**.

```
$ volatility -f memdump.mem --profile=Win7SP1x86 pslist
```

```
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$ volatility -f memdump.mem --profile=Win7SP1x86 pslist
Volatility Foundation Volatility Framework 2.6.1
Offset(V)  Name  mountPID  PIDs  PPID  T-C  Thds  sheet  Hnds  Wind  Sess  Wow64  Start-  Exit
-----
0x848338e8 System  4  0  90  547  -----  0  2019-07-31 11:49:59 UTC+0000
0x87002020 smss.exe  272  4  2  29  -----  0  2019-07-31 11:49:59 UTC+0000
0x8673f030 csrss.exe  360  352  9  381  0  0  2019-07-31 11:50:00 UTC+0000
0x867f7030 wininit.exe  412  352  3  74  0  0  2019-07-31 11:50:01 UTC+0000
0x867f55f8 csrss.exe  420  404  11  388  1  0  2019-07-31 11:50:01 UTC+0000
0x86879d40 winlogon.exe  468  404  110  Home  1  0  2019-07-31 11:50:01 UTC+0000
0x8684a6c0 services.exe  512  412  8  209  0  0  2019-07-31 11:50:01 UTC+0000
0x868d6b80 lsass.exe  520  412  7  610  0  0  2019-07-31 11:50:01 UTC+0000
0x868d7960 lsm.exe  528  412  10  150  0  0  2019-07-31 11:50:01 UTC+0000
0x8690e190 svchost.exe  636  512  10  361  0  0  2019-07-31 11:50:01 UTC+0000
0x86a33030 vmacthlp.exe  696  512  3  53  0  0  2019-07-31 11:50:01 UTC+0000
0x85c4e030 svchost.exe  728  512  9  310  0  0  2019-07-31 11:50:01 UTC+0000
0x86a46030 svchost.exe  780  512  18  502  0  0  2019-07-31 11:50:01 UTC+0000
0x86a7cd00 svchost.exe  876  512  15  382  0  0  2019-07-31 11:50:01 UTC+0000
0x86abd510 svchost.exe  948  512  41  1226  0  0  2019-07-31 11:50:01 UTC+0000
0x86ae5728 svchost.exe  1108  512  9  280  0  0  2019-07-31 11:50:02 UTC+0000
0x86b0bb78 svchost.exe  1240  512  16  491  0  0  2019-07-31 11:50:02 UTC+0000
0x86b6a378 spoolsv.exe  1348  512  12  321  0  0  2019-07-31 11:50:02 UTC+0000
0x86b754d0 svchost.exe  1384  512  18  313  0  0  2019-07-31 11:50:02 UTC+0000
0x86bca4a0 svchost.exe  1488  512  14  243  0  0  2019-07-31 11:50:02 UTC+0000
0x86c0ed18 VGAuthService. 1572  512  3  89  0  0  2019-07-31 11:50:02 UTC+0000
0x86c20640 vmtoolsd.exe 1596  512  9  306  0  0  2019-07-31 11:50:02 UTC+0000
0x86ca1790 svchost.exe 1916  512  6  90  0  0  2019-07-31 11:50:03 UTC+0000
0x86cac748 svchost.exe 1960  512  5  98  0  0  2019-07-31 11:50:03 UTC+0000
0x86ca4030 TPAutoConnSvc. 2012  512  9  129  0  0  2019-07-31 11:50:03 UTC+0000
0x86bd1988 WmiPrvSE.exe 332  636  10  291  0  0  2019-07-31 11:50:03 UTC+0000
0x86c4ca08 svchost.exe 2896  512  13  364  0  0  2019-07-31 11:52:03 UTC+0000
0xa75ffa80 SearchIndexer. 3012  512  13  734  0  0  2019-07-31 11:52:04 UTC+0000

0x84957030 notepad.exe 2592 1416 0 1 0 2019-07-31 13:39:28 UTC+0000 2019-07-31 13:39:29 UTC+0000
0x84f30648 whoami.exe 596 2304 0 1 0 2019-07-31 13:39:52 UTC+0000 2019-07-31 13:39:52 UTC+0000
0x86e1a9f0 whoami.exe 1880 3936 0 1 0 2019-07-31 13:40:09 UTC+0000 2019-07-31 13:40:09 UTC+0000
0x84a835a8 whoami.exe 2100 3992 0 1 0 2019-07-31 13:40:09 UTC+0000 2019-07-31 13:40:09 UTC+0000
0x86e1dcd0 whoami.exe 3972 2772 0 1 0 2019-07-31 13:40:10 UTC+0000 2019-07-31 13:40:10 UTC+0000
0x84dc3d40 rfhyMVOQxfc.exe 1808 2728 3 91 1 0 2019-07-31 13:45:17 UTC+0000
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$
```

Cette option nous permet d'afficher la liste des processus en cours de fonctionnement lors du dump.

Nous retrouverons ici plusieurs informations, voici les plus importantes :

- **offset** : l'adresse mémoire du processus ;
- **name** : le nom du processus en cours d'exécution ;
- **PID (Process IDentification)** : le numéro d'identification du processus ;
- **PPID (Parent Process ID)** : le PID du processus parent ;
- **start** : la date et l'heure de lancement du processus.

Dans notre cas, nous pouvons déjà identifier plusieurs processus suspects, comme les processus **rad5163B.tmp.exe** et **rfhyMVOQxfc.exe**

Lors de l'analyse des processus Windows, on peut vite se rendre compte qu'il existe tout un tas de processus en cours d'exécution. Lors d'une analyse mémoire, il est nécessaire de pouvoir identifier les processus légitimes et ceux qui ne le sont pas.

4- Listez les DLL d'un processus

Les DLL, pour **Dynamic Link Library**, sont les bibliothèques dans Windows. Ce sont des **fonctions préalablement codées et disponibles sur le système**. Pour éviter de recoder certaines fonctions, **l'API Windows fournit une liste de DLL** permettant de manipuler des données, de faire des connexions réseau ou encore d'écrire des fichiers.

Un logiciel malveillant va également utiliser ces API pour effectuer des actions sur le système. Via l'analyse mémoire, il sera possible de **lister les DLL** utilisées par un processus permettant de déduire son fonctionnement sur le système.

Avec Volatility, il est possible d'extraire les DLL utilisées pour un processus donné, avec l'option dlllist. Par exemple, pour le processus avec le **PID 1808** que nous avons précédemment identifié comme étant suspect :

```
0x86e1dcd0 whoami.exe 3972 2772 0 -----
0x84dc3d40 rfhyMVOQxfc.exe 1808 2728 3 91
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$
```

\$ volatility -f memdump.mem --profile=Win7SP1x86 dlllist -p 1808

```
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump Forensics-Post... Forensics-Post...
$ volatility -f memdump.mem --profile=Win7SP1x86 dlllist -p 1808
Volatility Foundation Volatility Framework 2.6.1
*****
rfhyMVOQxfc.exe pid: 1808
Command line : "C:\Users\johnoc\AppData\Local\Temp\rad41020.tmp\rfhyMVOQxfc.exe"
Service Pack 1
*****
Base          Size      LoadCount LoadTime          Path
-----
0x00400000 0x16000 0xffff 1970-01-01 00:00:00 UTC+0000 C:\Users\johnoc\AppData\Local\Temp\rad41020.tmp\rfhyMVOQxfc.exe
0x777d0000 0x13c000 0xffff 1970-01-01 00:00:00 UTC+0000 C:\Windows\SYSTEM32\ntdll.dll
0x773f0000 0xd4000 0xffff 2019-07-31 13:45:17 UTC+0000 C:\Windows\system32\kernel32.dll
0x75ac0000 0x4a000 0xffff 2019-07-31 13:45:17 UTC+0000 C:\Windows\system32\KERNELBASE.dll
0x76920000 0xac000 0xffff 2019-07-31 13:45:17 UTC+0000 C:\Windows\system32\MSVCRT.dll
0x76e30000 0xa0000 0xffff 2019-07-31 13:45:17 UTC+0000 C:\Windows\system32\ADVAPI32.dll
0x76d40000 0x19000 0xffff 2019-07-31 13:45:17 UTC+0000 C:\Windows\SYSTEM32\sechost.dll
0x77720000 0xa1000 0xffff 2019-07-31 13:45:17 UTC+0000 C:\Windows\system32\RPCRT4.dll
0x6cab0000 0x7000 0xffff 2019-07-31 13:45:17 UTC+0000 C:\Windows\system32\WSOCK32.dll
0x76df0000 0x35000 0xffff 2019-07-31 13:45:17 UTC+0000 C:\Windows\system32\WS2_32.dll
0x77910000 0x6000 0xffff 2019-07-31 13:45:17 UTC+0000 C:\Windows\system32\NSI.dll
0x75360000 0x3c000 0x2 2019-07-31 13:45:17 UTC+0000 C:\Windows\system32\mswsock.dll
0x770c0000 0xc9000 0x35 2019-07-31 13:45:17 UTC+0000 C:\Windows\system32\user32.dll
0x75e20000 0x4e000 0x2f 2019-07-31 13:45:17 UTC+0000 C:\Windows\system32\GDI32.dll
0x77920000 0xa000 0xc 2019-07-31 13:45:17 UTC+0000 C:\Windows\system32\LPK.dll
```

Nous pouvons voir ici que l'emplacement du fichier **C:\Users\johnoc\AppData\Local\Temp\rad41020.tmp\rfhyMVOQxfc.exe** n'est pas commun. Ce qui nous donne des indices pour notre investigation.

5- Analyse du registre

Le registre contient **divers paramètres et configurations pour le système d'exploitation Windows**. En tant que composant principal de Windows, il est accédé en permanence pendant le temps d'exécution. Ainsi, il est logique que le système place en mémoire tout ou partie des fichiers du registre.

En outre, le registre Windows détient une mine d'informations utiles à des fins d'analyses. Par exemple, il sera possible de **déterminer les programmes récemment exécutés**, d'extraire les hash de mots de passe à des fins d'audit, ou encore **d'étudier les clés et les valeurs introduites par un code malveillant dans le système**.

Avec Volatility, il est possible d'extraire les informations du registre et de lister les fichiers correspondants avec l'option hivelist.

\$ volatility -f memdump.mem --profile=Win7SP1x86 hivelist

```
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$ volatility -f memdump.mem --profile=Win7SP1x86 hivelist
Volatility Foundation Volatility Framework 2.6.1
Virtual    Physical    Name
-----
0x95281008 0x675df008 \??\C:\Users\johnoc\AppData\Local\Microsoft\Windows\UsrClass.dat
0x95289008 0x6c12a008 \??\C:\Users\johnoc\ntuser.dat
0xaff9a2c8 0x06f4f2c8 \SystemRoot\System32\Config\SECURITY
0x820ee9c8 0x1d9779c8 \??\C:\System Volume Information\Syscache.hve
0x89810198 0x2da23198 [no name]
0x8981c008 0x2cd71008 \REGISTRY\MACHINE\SYSTEM
0x898459c8 0x2cd9c9c8 \REGISTRY\MACHINE\HARDWARE
0x898ca5c0 0x718135c0 \SystemRoot\System32\Config\DEFAULT
0x8a6579c8 0x723979c8 \SystemRoot\System32\Config\SAM
0x8a6f89c8 0x616399c8 \??\C:\Windows\ServiceProfiles\NetworkService\NTUSER.DAT
0x8a77e008 0x7847f008 \??\C:\Windows\ServiceProfiles\LocalService\NTUSER.DAT
0x8f091900 0x006a5900 \Device\HarddiskVolume1\Boot\BCD
0x8f100098 0x0734d098 \SystemRoot\System32\Config\SOFTWARE
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$
```

Ces deux adresses sont des registres contenant les mots de passes hashés des comptes du système.

Avec ces informations et l'option **hashdump**, il sera possible de dumper les hash des mots de passe des comptes Windows.

```
$ volatility -f memdump.mem --profile=Win7SP1x86 hashdump -y 0x8981c008 -s 0x8a6579c8
```

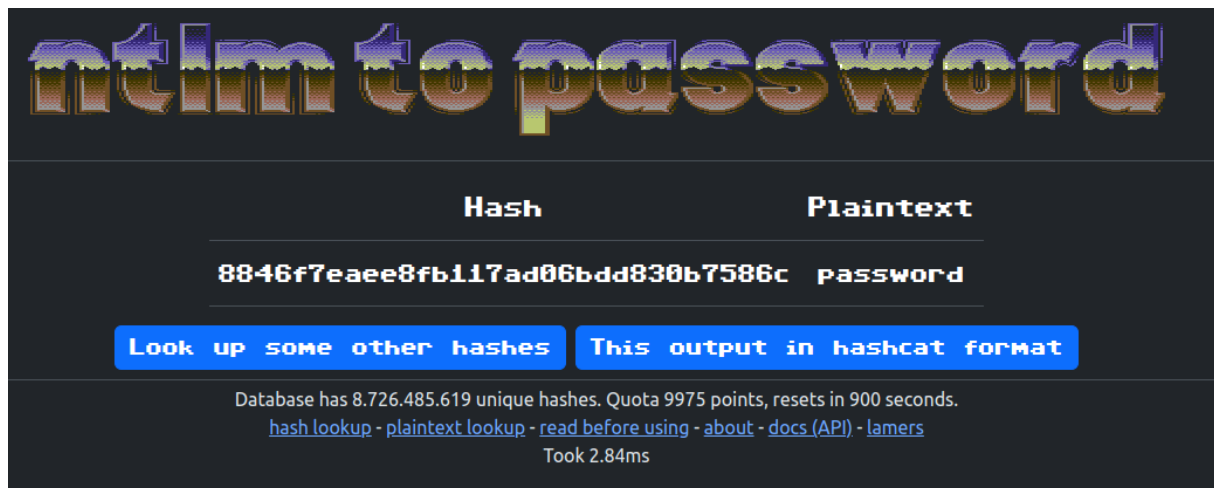
```
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$ volatility -f memdump.mem --profile=Win7SP1x86 hashdump -y 0x8981c008 -s 0x8a6579c8
Volatility Foundation Volatility Framework 2.6.1
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
johnoc:1000:aad3b435b51404eeaad3b435b51404ee:8846f7eae8fb117ad06bdd830b7586c:::
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$
```

Nous allons utiliser le site <https://ntlm.pw/> pour voir en claire les mots de passes hashés.

Une fois sur le site on prend le mot de passe hashé et on le copie sur le champ bleu comme suit :

The screenshot shows a web browser window with the URL <https://ntlm.pw/>. The page has a dark theme and a large, stylized title "ntlm to password" at the top. Below the title, it says "Input NT/LM hashes in hex format, one per line" and "(Partial hashes accepted, 16 hex digit prefix or more!)". A large blue rectangular input field contains the hash "8846f7eae8fb117ad06bdd830b7586c". At the bottom, there are radio buttons for "Hash type for lookup:" with options NT (selected), LM, MD5, SHA1, and SHA256. A blue button labeled "Look up hashes" is positioned below the input field. At the very bottom, small text indicates "Database has 8.726.485.619 unique hashes. Quota 10000 points, resets in 900 seconds." and "Took 0.16ms".

Ensuite on clique sur «Look up hashes » :



Ainsi nous arrivons bien à afficher le mot de passe haché en clair.

6- Analyse des connexions réseaux

Presque tous les logiciels malveillants peuvent **communiquer sur le réseau avec leur serveur de Command et de Control**, pour se propager, ou encore pour la mise en place d'une porte dérobée.

Ces actions utilisent **les API réseaux de Windows**, ce qui laisse inévitablement des traces en mémoire. L'analyse mémoire du réseau permettra de recouvrer des informations telle que des **connexions d'IP distantes, les ports de connexion et même certaines données échangées**.

Volatility propose plusieurs options permettant d'extraire des informations de connexion. Les options connections, sockscan et socket fonctionnent uniquement sur des systèmes antérieurs à **Windows 7**.

Toutefois, il est possible de lister les connexions réseaux actives sur les systèmes plus récents, avec l'option **netscan**.

```
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$ volatility -f memdump.mem --profile=Wln7SP1x86 netscan
Volatility Foundation Volatility Framework 2.6.1
```

Offset(P)	Proto	Local Address	Foreign Address	State	Pid	Owner	Created
0x19472208	UDPv4	0.0.0.0:3702	0.0.0.0:*	*	1488	svchost.exe	2019-07-31 12:43:12 UTC+0000
0x19472208	UDPv6	:::3702	:::*	*	1488	svchost.exe	2019-07-31 12:43:12 UTC+0000
0x24d773a0	UDPv4	0.0.0.0:5355	0.0.0.0:*	*	1240	svchost.exe	2019-07-31 13:43:08 UTC+0000
0x5d30e208	UDPv4	0.0.0.0:5355	0.0.0.0:*	*	1488	svchost.exe	2019-07-31 12:43:12 UTC+0000
0x5d30e208	UDPv6	:::3702	:::*	*	1488	svchost.exe	2019-07-31 12:43:12 UTC+0000
0x6ec043a0	UDPv4	0.0.0.0:5355	0.0.0.0:*	*	1240	svchost.exe	2019-07-31 13:43:08 UTC+0000
0x7beddf50	UDPv6	:::11900	:::*	*	1488	svchost.exe	2019-07-31 12:43:10 UTC+0000
0x7ce3fe20	UDPv6	fe80::94b5:ad60:33d0:3773:1900	:::*	*	1488	svchost.exe	2019-07-31 12:43:10 UTC+0000


```

0x7ee2edf8      TCPv4      172.16.169.167:49848      172.16.169.164:4444      ESTABLISHED      1416      rad5163B.tmp.e
0x7eeb9138      TCPv4      172.16.169.167:49850      172.16.169.164:4444      CLOSED           1292      rfhyMVOQxfc.ex
0x7ef91008      TCPv4      172.16.169.167:49858      172.16.169.164:4444      ESTABLISHED      1808      rfhyMVOQxfc.ex
0x7f1a9820      TCPv4      172.16.169.167:49857      172.16.169.164:4444      CLOSED           24
0x7f224220      TCPv4      172.16.169.167:49852      66.102.1.108:993         ESTABLISHED      3476      OUTLOOK.EXE
0x7f34f278      TCPv4      -:49789                    54.154.128.160:443       CLOSED           2472      systeminfo.exe
0x7f3c9568      TCPv4      172.16.169.167:49855      172.16.169.164:4444      CLOSED           2708      bVwHCYX.exe
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$
```

Nous pouvons voir que les processus identifiés effectuent plusieurs connexions vers l'adresse ip **172.16.169.164:4444**.

L'analyse mémoire permet de révéler **énormément de choses sur l'environnement infecté**. Un processus malveillant sera plus facile à détecter et à analyser sur un dump mémoire que sur un environnement en cours de fonctionnement. Par ailleurs, il sera possible **d'accéder à d'autres informations cruciales sur le système**.

7- Découverte des différents fichiers de mémoire

Il existe **différent type de fichiers** qui peuvent être utilisés pour l'analyse mémoire. Windows utilise des **fichiers système pour pouvoir stocker certaines informations** qui sont propres à des fonctionnalités internes, telles que l'hibernation ou la pagination.

Hiberfil.sys

Hiberfil.sys est le fichier utilisé par défaut par Windows pour **enregistrer l'état de la machine** dans le cadre du processus d'hibernation. Ce processus permet de restaurer l'état de la machine, c'est-à-dire sa mémoire vive, au moment du démarrage, pour retrouver l'état lors de la mise hors tension.

Le système d'exploitation conserve également un descripteur de fichiers ouverts sur ce fichier afin qu'aucun utilisateur, y compris l'administrateur, ne puisse lire le fichier lorsque le système est en cours d'exécution.

Le fichier hiberfil.sys est par défaut compressé ; pour pouvoir l'analyser avec Volatility, il faudra d'abord utiliser l'option **imagecopy** pour décompresser l'image.

La pagination est un concept qui permet **d'étendre la mémoire RAM disponible** en stockant dans un fichier des éléments de la RAM qui ne sont pas utilisés. Windows utilise le fichier système Pagefile.sys pour stocker ces informations, qui peuvent également être exploitées durant l'investigation.

Bien que Windows prenne en charge jusqu'à **16 fichiers de pagination**, en pratique un seul est utilisé. Ce fichier, stocké dans « %SystemDrive%\pagefile.sys », est un fichier système caché.

Étant donné que le système d'exploitation **maintient ce fichier ouvert pendant son fonctionnement normal**, il ne peut jamais être lu ou consulté par un utilisateur. Toutefois, il peut contenir des informations intéressantes lors d'une analyse post mortem, une fois extrait.

Pagefile.sys ne peut pas être parsé par Volatility. Toutefois, il est possible d'extraire des informations avec la commande strings. Attention, notez que ceci peut être extrêmement long et qu'il est préférable de coupler la commande "strings" avec la commande "grep".

8- Affichage de l'arborescence des processus avec pstree

Nous avons vu qu'il était possible de lister les processus en cours de fonctionnement dans le dump mémoire avec la commande pslist. Il existe toutefois une autre commande, pstree, qui permet d'afficher **la liste des processus sous forme d'arborescence**.

L'option pstree peut s'avérer très utile car elle permettra d'identifier les processus parents d'un processus en particulier. Ainsi, vous pourrez noter les structures suspectes. Par exemple, il n'est pas normal qu'un CMD soit un processus fils d'Internet Explorer !

Voici la commande à exécuter pour afficher l'arborescence des processus :

```
$ volatility -f memdump.mem --profile=Win7SP1x64 pstree
```

```
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$ volatility -f memdump.mem --profile=Win7SP1x86 pstree
Volatility Foundation Volatility Framework 2.6.1
```

Name	Pid	PPid	Thds	Hnds	Time	Poses	Threat
0x867f7030:wininit.exe	412	352	3	74	2019-07-31 11:50:01	UTC+0000	
0x8684a6c0:services.exe	512	412	8	209	2019-07-31 11:50:01	UTC+0000	
0x84a49a80:taskhost.exe	1644	512	9	205	2019-07-31 11:56:18	UTC+0000	
0x86a46030:svchost.exe	780	512	18	502	2019-07-31 11:50:01	UTC+0000	
0x85c4e030:svchost.exe	728	512	9	310	2019-07-31 11:50:01	UTC+0000	
0xa75ffa80:SearchIndexer.	3012	512	13	734	2019-07-31 11:52:04	UTC+0000	
0x86cac748:svchost.exe	1960	512	5	98	2019-07-31 11:50:03	UTC+0000	
0x84964d40:wmpnetwk.exe	2408	512	9	223	2019-07-31 11:56:25	UTC+0000	
0x86abd510:svchost.exe	948	512	41	1226	2019-07-31 11:50:01	UTC+0000	
0x86a33030:vmacthlp.exe	696	512	3	53	2019-07-31 11:50:01	UTC+0000	
0x86c20640:vmtoolsd.exe	1596	512	9	306	2019-07-31 11:50:02	UTC+0000	
0x86c4ca08:svchost.exe	2896	512	13	364	2019-07-31 11:52:03	UTC+0000	
0x86b6a378:spoolsv.exe	1348	512	12	321	2019-07-31 11:50:02	UTC+0000	
0x86bca4a0:svchost.exe	1488	512	14	243	2019-07-31 11:50:02	UTC+0000	
0x86ae5728:svchost.exe	1108	512	9	280	2019-07-31 11:50:02	UTC+0000	
0x86b0bb78:svchost.exe	1240	512	16	491	2019-07-31 11:50:02	UTC+0000	
0x86c0ed18:VGAAuthService.	1572	512	3	89	2019-07-31 11:50:02	UTC+0000	
0x86ca4030:TPAutoConnSvc.	2012	512	9	129	2019-07-31 11:50:03	UTC+0000	
0x84ba8890:TPAutoConnect.	1984	2012	3	111	2019-07-31 11:56:19	UTC+0000	
0x84b1c030:WINWORD.EXE	3544	588	13	621	2019-07-31 12:45:34	UTC+0000	
0x84e19030:rad5163B.tmp.e	1416	3544	11	472	2019-07-31 12:45:47	UTC+0000	
0x84a46030:systeminfo.exe	2472	1416	0	-----	2019-07-31 12:51:36	UTC+0000	
0x84aebf8:cscrip.exe	2728	1416	5	198	2019-07-31 12:53:57	UTC+0000	
0x84d165e8:rfhyMVOQxfc.ex	1292	2728	0	-----	2019-07-31 12:53:57	UTC+0000	
0x84dc3d40:rfhyMVOQxfc.ex	1808	2728	3	91	2019-07-31 13:45:17	UTC+0000	
0x84ad3a08:cmd.exe	2204	1416	0	-----	2019-07-31 12:55:36	UTC+0000	

Nous pouvons voir énormément de processus en cours de fonctionnement sur le système. Il sera ainsi possible d'identifier un processus suspect.

Par exemple, dans notre cas, nous pouvons voir que le processus avec le **PID 1416** précédemment identifié est fils du process avec le **PID 3544** correspondant au processus Winword.

Affichez les processus cachés avec psxview

Une autre commande qui peut être utilisée pour lister les processus est **psxview**. Cette commande permet d'afficher les processus cachés.

\$ volatility -f memdump.mem --profile=Win7SP1x86 psxview

```
sansforensics@siftworkstation: ~/Downloads/OC-002-mendump
$ volatility -f memdump.mem --profile=Win7SP1x86 psxview
Volatility Foundation Volatility Framework 2.6.1
Offset(P) Name PID pslist psscan thrddproc pspcid csrss session deskthrd ExitTime
-----
0x7d4d6b80 lsass.exe 520 True True True True True True True False
0x7d27cd00 svchost.exe 876 True True True True True True True False
0x7ef04030 conhost.exe 2876 True True True True True True True False
0x7d04ca08 svchost.exe 2896 True True True True True True True False
0x7ee19030 rad5163B.tmp.e 1416 True True True True True True True False
0x7d0a1790 svchost.exe 1916 True True True True True True True True
0x7f2787d0 vmtoolsd.exe 2500 True True True True True True True False
0x7d00ed18 VGAuthService.exe 1572 True True True True True True True False
0x7f548030 OUTLOOK.EXE 3476 True True True True True True True False
0x7d3ca4a0 svchost.exe 1488 True True True True True True True True
0x7d7f7030 wininit.exe 412 True True True True True True True True
0x7d4b8030 dwm.exe 1176 True True True True True True True False
0x7d246030 svchost.exe 780 True True True True True True True True
0x7d2e5728 svchost.exe 1108 True True True True True True True True
-----
0x7f1165e8 rfhyMVOQxfc.exe 1292 True True False True False True False 2019-07-31 13:45:12 UTC+0000
0x7d170d40 net1.exe 2220 True True False True False True False 2019-07-31 12:51:36 UTC+0000
0x7ce1a9f0 whoami.exe 1880 True True False True False True False 2019-07-31 13:40:09 UTC+0000
0x7d083030 whoami.exe 2924 True True False True False True False 2019-07-31 13:38:22 UTC+0000
0x7f2f7030 net1.exe 4052 True True False True False True False 2019-07-31 12:51:28 UTC+0000
0x7f1c5d40 tior.exe 4012 False True False False False False False 2019-07-31 13:45:03 UTC+0000
0x7f58a660 bVwHCYX.exe 2708 False True False False False False False 2019-07-31 13:45:02 UTC+0000
0x7f3af6c8 conhost.exe 2312 False True False False False False False
0x7eee7bc8 chrome.exe 4076 False True False False False False False 2019-07-31 12:44:26 UTC+0000
0x7f35ec48 dlhlost.exe 628 False True False False False False False 2019-07-31 13:40:16 UTC+0000
0x7ef59158 dlhlost.exe 3412 False True False False False False False 2019-07-31 13:45:46 UTC+0000
0x7f2f43d0 conhost.exe 3848 False True False False False False False 2019-07-31 13:44:41 UTC+0000
0x7eb048f0 dlhlost.exe 2652 False True False False False False False 2019-07-31 13:40:16 UTC+0000
0x7d1ab030 RGoEsDNCZhEnL. 1876 False True False False False False False 2019-07-31 13:45:03 UTC+0000
0x7f0399b0 conhost.exe 1860 False True False False False False False 2019-07-31 13:45:03 UTC+0000
sansforensics@siftworkstation: ~/Downloads/OC-002-mendump
$
```

Si un processus est caché, les colonnes **pslist**, **psscan** seront marquées comme **False**.

9- Détection de l'injection de code avec malfind

La commande **malfind** peut être utilisée pour détecter de l'injection de code malveillant. Pour cela, utilisez cette commande :

`$volatility -f memdump.mem --profile=Win7SP1x86 malfind`

```
Process: rad5163B.tmp.e Pid: 1416 Address: 0x4ec0000
Vad Tag: VadS Protection: PAGE_EXECUTE_READWRITE
Flags: CommitCharge: 208, MemCommit: 1, PrivateMemory: 1, Protection: 6

0x04ec0000 4d 5a 90 00 03 00 00 00 04 00 00 00 ff ff 00 00 MZ.....
0x04ec0010 b8 00 00 00 00 00 00 00 40 00 00 00 00 00 00 00 Windows...@...Network-
0x04ec0020 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 Forensics-Post...Forensics-Pos
0x04ec0030 00 00 00 00 00 00 00 00 00 00 00 00 00 00 10 01 00 00 .....

0x04ec0000 4d DEC EBP
0x04ec0001 5a POP EDX
0x04ec0002 90 NOP
0x04ec0003 0003 ADD [EBX], AL
0x04ec0005 0000 ADD [EAX], AL
0x04ec0007 000400 ADD [EAX+EAX], AL
0x04ec000a 0000 ADD [EAX], AL
0x04ec000c ff DB 0xff
0x04ec000d ff00 INC DWORD [EAX]
0x04ec000f 00b800000000 ADD [EAX+0x0], BH
0x04ec0015 0000 ADD [EAX], AL
0x04ec0017 004000 ADD [EAX+0x0], AL
```

Nous pouvons voir un extrait de l'en-tête du processus avec le PID1416. Nous pouvons voir ici qu'il s'agit d'un exécutable avec l'en-tête **MZ**.

NB : L'injection de code permet de dissimuler un processus malveillant dans un processus légitime.

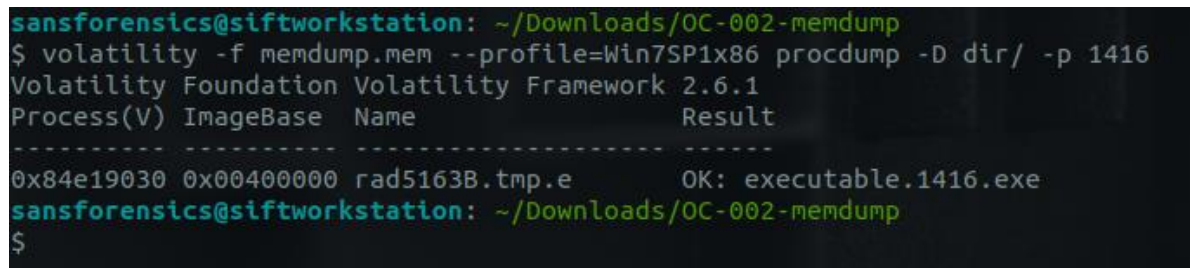
10- Process dump avec procdump

Lors de l'analyse mémoire, il sera possible de dumper un **processus en particulier pour l'analyser en détail**. Il est également possible de réaliser un dump mémoire d'un processus en cours d'exécution.

Ce dump est un **instantané d'un processus en cours d'exécution** et contient les modules chargés pour l'application à un moment donné.

Volatility possède une option permettant de dumper un processus spécifique.

```
$ volatility -f memdump.mem --profile=Win7SP1x86 procdump -D dir/ -p 1416
```



```
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$ volatility -f memdump.mem --profile=Win7SP1x86 procdump -D dir/ -p 1416
Volatility Foundation Volatility Framework 2.6.1
Process(V) ImageBase Name Result
-----
0x84e19030 0x00400000 rad5163B.tmp.e OK: executable.1416.exe
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$
```

La sortie de la commande “volatility -f memdump.mem --profile=Win7SP1x86 procdump -D dir/ -p 1416” indique que vous avez extrait avec succès l'exécutable en mémoire appartenant au processus PID 1416

OK: executable.1416.exe : Cela signifie que :

Le dump du processus (PID 1416) s'est bien effectué.

L'exécutable a été sauvegardé dans le dossier **dir/** sous le nom **executable.1416.exe**.

 Identifions le type de fichier :

Utilisons la commande **file** pour vérifier s'il s'agit bien d'un exécutable Windows (Portable Executable - PE) :

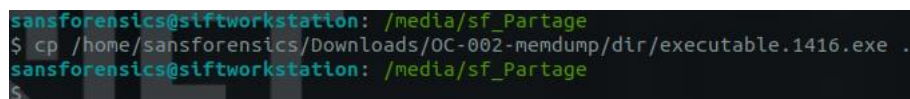
```
$ file dir/executable.1416.exe
```



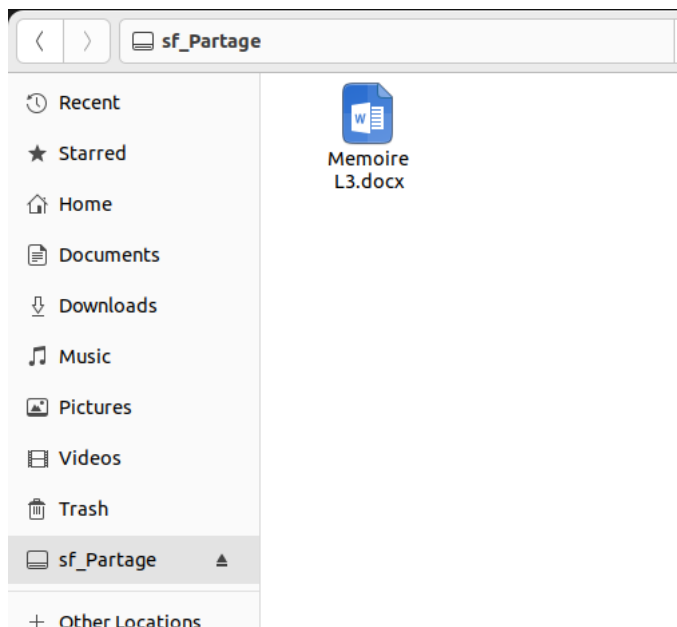
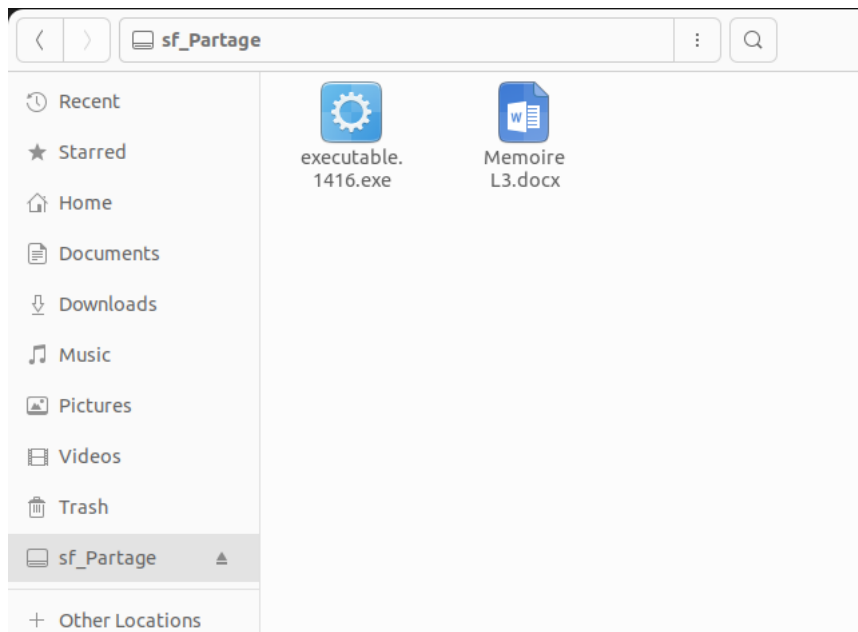
```
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$ file dir/executable.1416.exe
dir/executable.1416.exe: PE32 executable (GUI) Intel 80386, for MS Windows
sansforensics@siftworkstation: ~/Downloads/OC-002-memdump
$
```

Cela confirme qu'il s'agit bien d'un exécutable Windows 32 bits.

 Copions le fichier dans le dossier partager de windows et observons la réaction de windows :



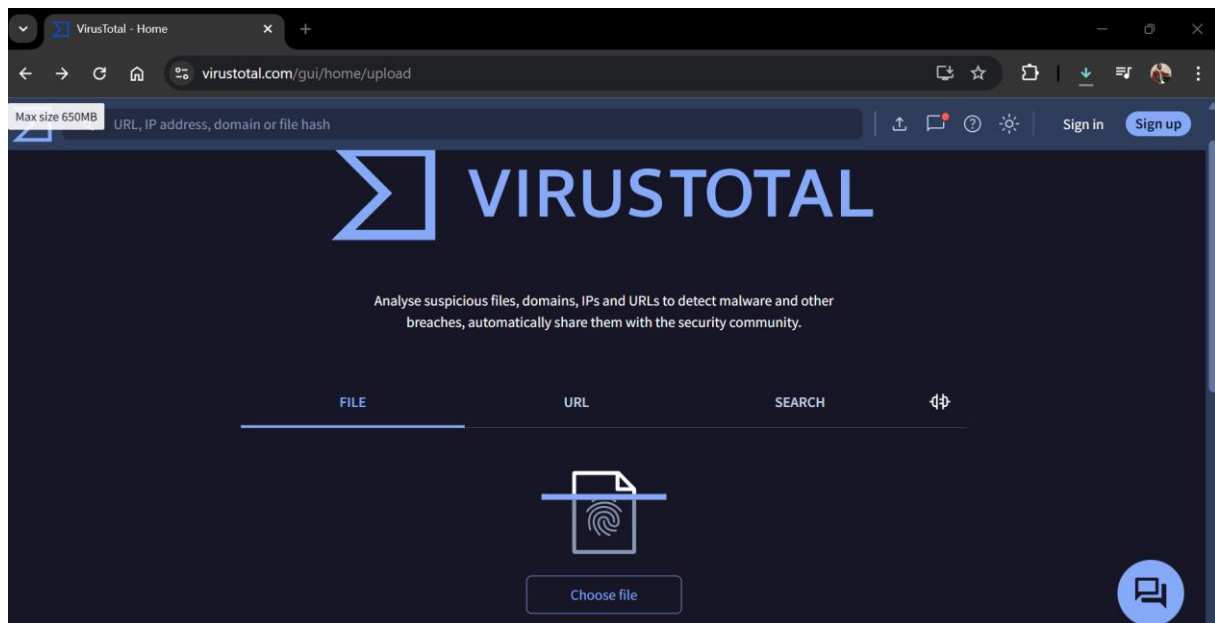
```
sansforensics@siftworkstation: /media/sf_Partage
$ cp /home/sansforensics/Downloads/OC-002-memdump/dir/executable.1416.exe .
sansforensics@siftworkstation: /media/sf_Partage
$
```



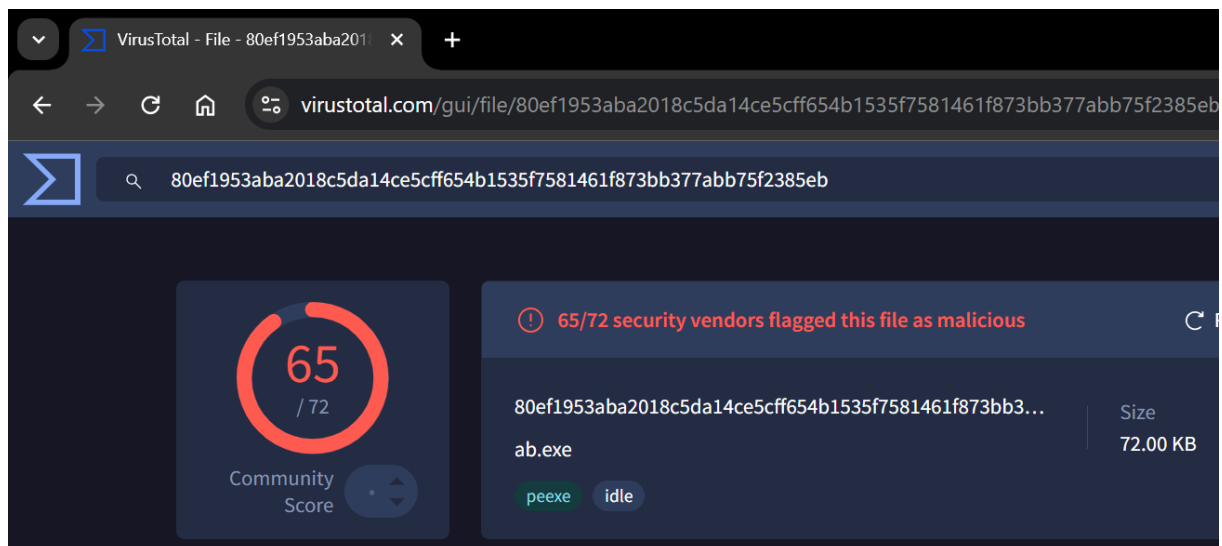
Après quelques instants on voit que Windows a supprimé le fichier pour cause de sécurité.



Analysons le fichier avec virustotal :



Choisissons le fichier et observons les résultats :



Extraire les chaînes de caractères

Cela permet de révéler des informations comme :

- Noms de DLL utilisées
- Commandes exécutées
- URLs ou adresses IP
- Clés de register

\$ strings dir/executable.1416.exe | less

La commande **svcsan** permet de lister les services sur la machine en cours d'investigation.

Les malwares peuvent utiliser les services Windows comme moyen de persistance permettant de survivre au redémarrage. Il peut être intéressant d'analyser ces éléments pour détecter un mécanisme de persistance. Le [malware Emotet](#) utilisait cette technique pour se réexécuter.

- Allons plus loin avec d'autres options de Volatility

Volatility permet une analyse en profondeur de la mémoire. Nous n'allons pas voir en détail toutes les options possibles, mais voici quelques autres commandes qui pourront vous servir :

- **cmdscan** pour extraire l'historique des commandes entrées dans l'invite de commande, et donc voir quelles ont été les dernières commandes entrées avant l'incident. Si vous détectez une commande suspecte entrée juste avant l'incident, vous avez peut-être trouvé le déclencheur du malware !
- **yarascan** permettant d'utiliser des **YARA rules**. Les **YARA rules** sont un moyen de chercher des caractéristiques particulières des malwares dans des fichiers, afin de détecter des fichiers malveillants. Ce sont des techniques particulières, mais sachez que vous pouvez les utiliser avec Volatility. Je vous invite à consulter [cette page sur les YARA rules](#) pour en savoir un peu plus.
- Les plugins Volatility

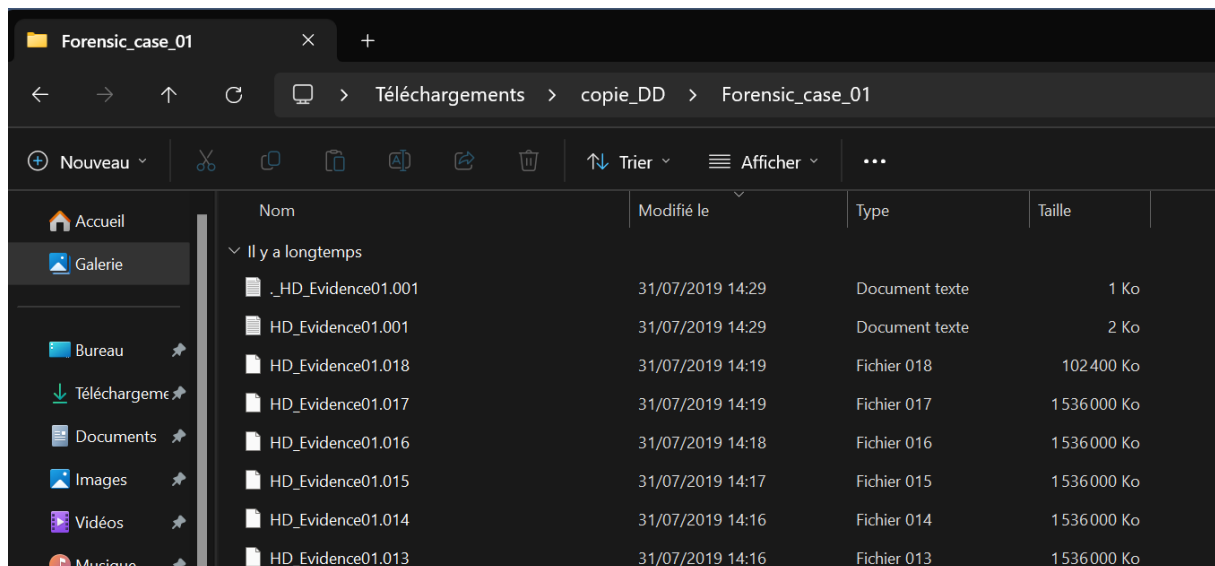
Il est également possible de développer et d'utiliser des **plugins** complémentaires, par exemple pour extraire des informations relatives à un malware en particulier.

Pour utiliser un plugin, il suffit de spécifier l'emplacement du plugin avec l'option **--plugins=""**. Nous pouvons voir ici un exemple avec le plugin [autoruns](#). Ce plugin permet d'extraire les clés de registre **Run** permettant l'exécution de programmes à chaque démarrage. En d'autres termes, il vous permet de détecter quelles sont les manières dont le malware persiste sur la machine.

V- Analyse de la copie du disque dur

Pour analyser le disque dur nous devons posséder la copie du disque que nous pouvons télécharger en cliquant sur https://s3-eu-west-1.amazonaws.com/course-oc-static.com/courses/1750151/copie_DD.tar.gz.

Une fois le fichier téléchargé, on décompresse le fichier :



Nous allons à présent étudier **comment les données sont stockées sur un système Windows** et comment réaliser une **chronologie des évènements**, afin de mieux comprendre ce qu'il est passé sur la machine.

Pour ce faire nous allons extraire la **MFT** pour l'analyser.

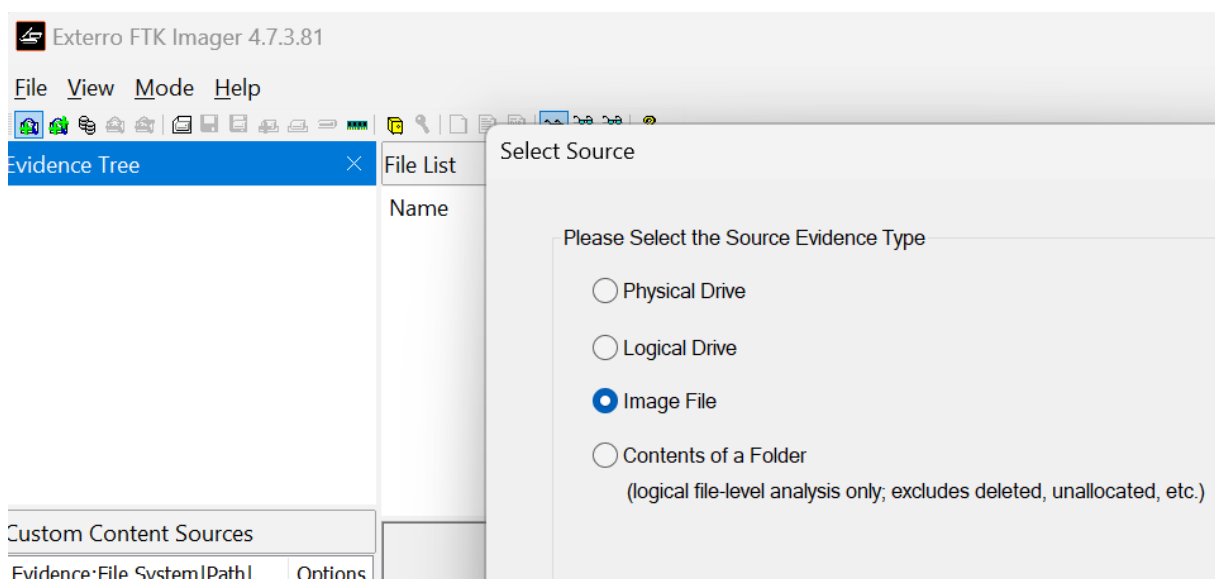
La **MFT** est une **base de données relationnelle composée de lignes d'enregistrements de fichiers** et de colonnes d'attributs de fichiers. Il contient au moins une entrée pour chaque fichier d'un volume NTFS, y compris la MFT elle-même.



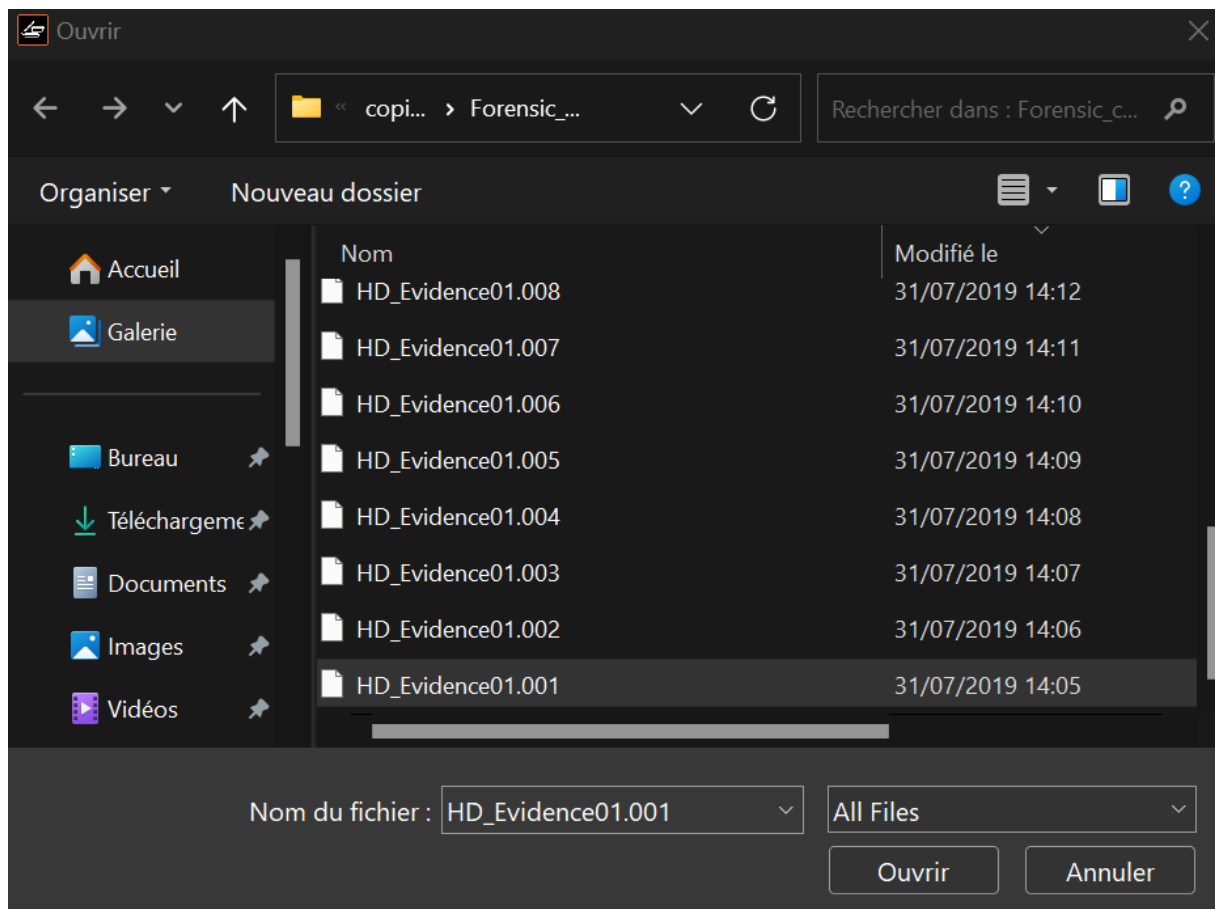
Extraction de la MFT

La MFT se situe à la racine du disque dur. Pour y accéder, il suffit d'utiliser le **logiciel FTK Imager**. La copie d'écran ci-dessous nous montre la MFT sur le disque monté.

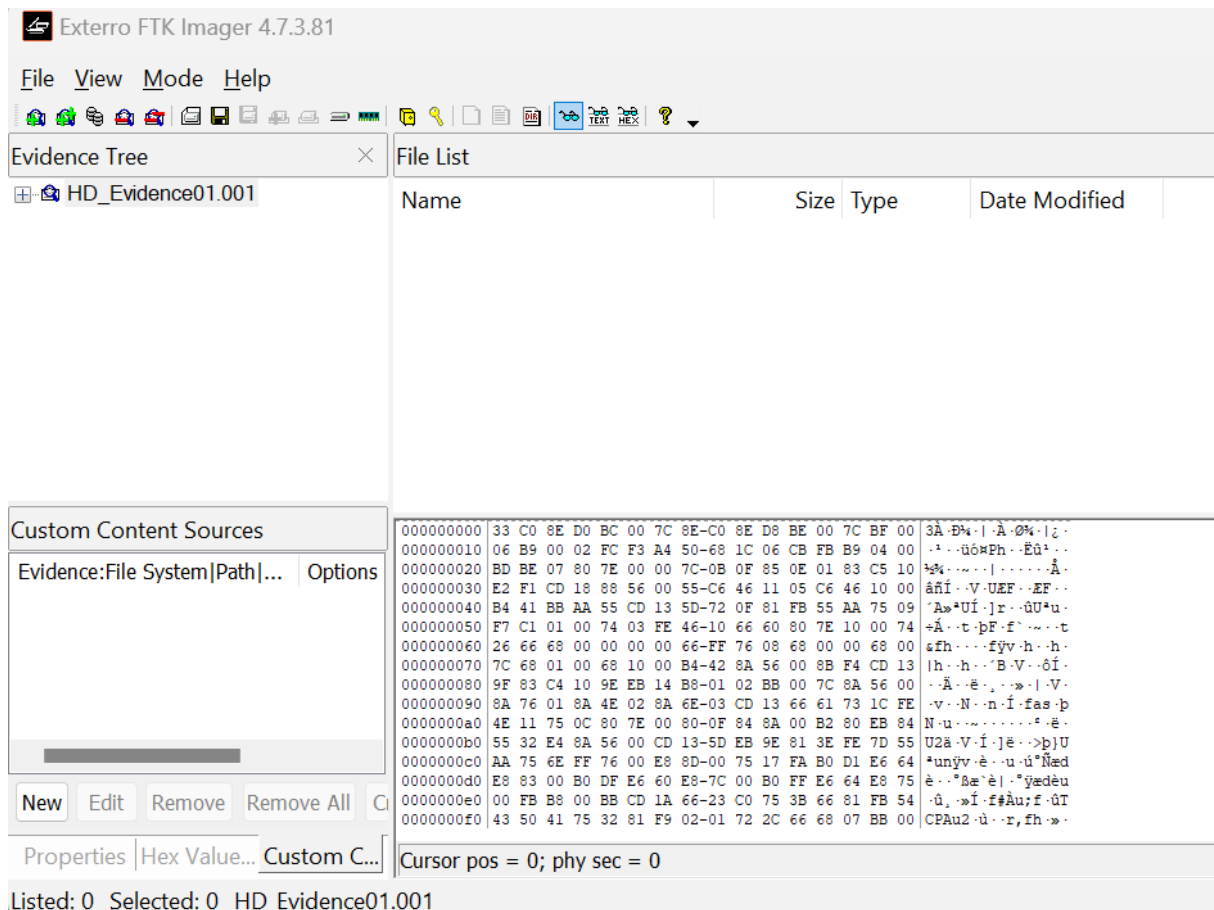
Cliquons sur **Add Evidence Item > Image File > Sélectionner copie disque dur :**



Puis on clique sur **HD_EVIDENCE01.001** :



Ensuite, le contenu du disque sera disponible sur le panneau de gauche comme la capture ci-dessous :



Cliquons sur + **HD_EVIDENCE01.001** puis sur + **partition 2**, encore sur + **NONAME (NTFS)**.

Exterro FTK Imager 4.7.3.81

File View Mode Help

Evidence Tree

- HD_Evidence01.001
 - Partition 1 [100MB]
 - Partition 2 [25498MB]
 - NONAME [NTFS]
 - [orphan]
 - [root]
 - [unallocated space]
 - Unpartitioned Space [basic disk]

File List

Name	Size	Type	Date Modified
[orphan]	-	Folder (Pl...	
[root]	56 (1 KB)	Directory	31/07/2019 12:...
[unallocated space]	-	Unallocat...	
backup boot sector	512 (1 KB)	Filesystem...	
file system slack	3584 (4 ...)	Filesystem...	

Custom Content Sources

Evidence:File System[Path]... Options

New Edit Remove Remove All

Properties Hex Value... Custom C...

Listed: 5 Selected: 0 HD_Evidence01.001/Partition 2 [25498MB]/NONAME [NTFS]

Le contenu du système se trouve dans le répertoire **root** et le fichier **MFT** est également présent à la racine du fichier root.

Pour dumper la **MFT**, il suffit de faire un **clic droit** puis cliquer sur **export file** :

Exterro FTK Imager 4.7.3.81

File View Mode Help

Evidence Tree

- [root]
 - \$BadClus
 - \$Extend
 - \$Recycle.Bin
 - \$Secure
 - Documents and Se
 - MSOCache
 - PerfLogs
 - Program Files
 - ProgramData

File List

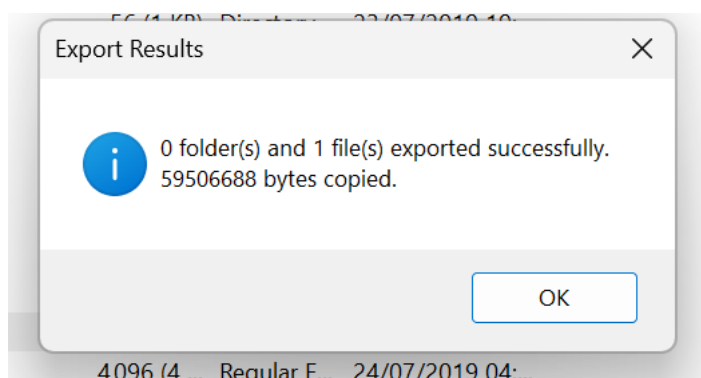
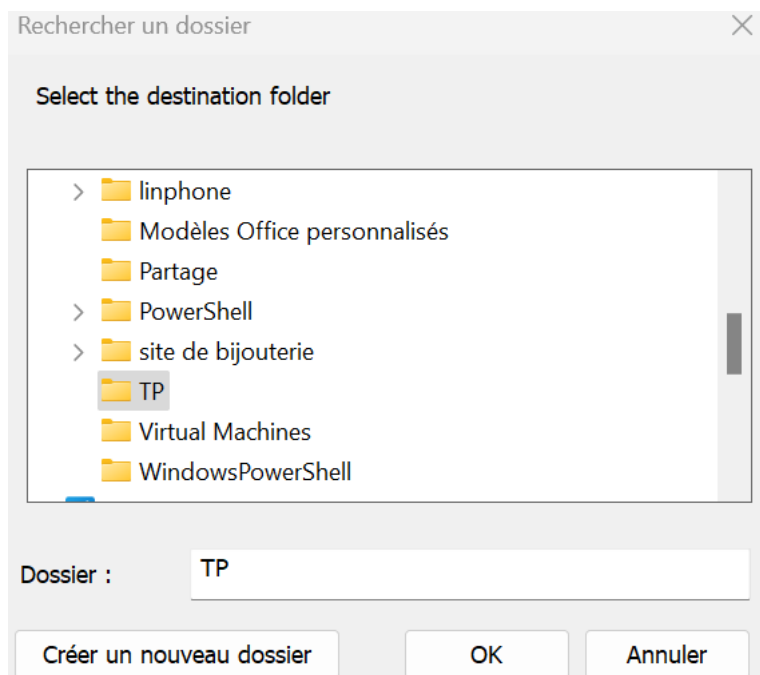
Name	Size	Type	Date Modified
Users	56 (1 KB)	Directory	23/07/2
Windows	416 (1 KB)	Directory	31/07/2
\$AttrDef	2560 (3 ...)	Regular F...	24/07/2
\$BadClus	-	Regular F...	24/07/2
\$Bitmap	815936 (...)	Regular F...	24/07/2
\$Boot	8192 (8 ...)	Regular F...	24/07/2
\$I30	4096 (4 ...)	NTFS Ind...	31/07/2
\$LogFile	6710886...	Regular F...	24/07/2
\$MFT	56 (1 KB)	NTFS Log...	31/07/2
\$LogFile	131072 (...	Regular F...	24/07/2

Custom Content Sources

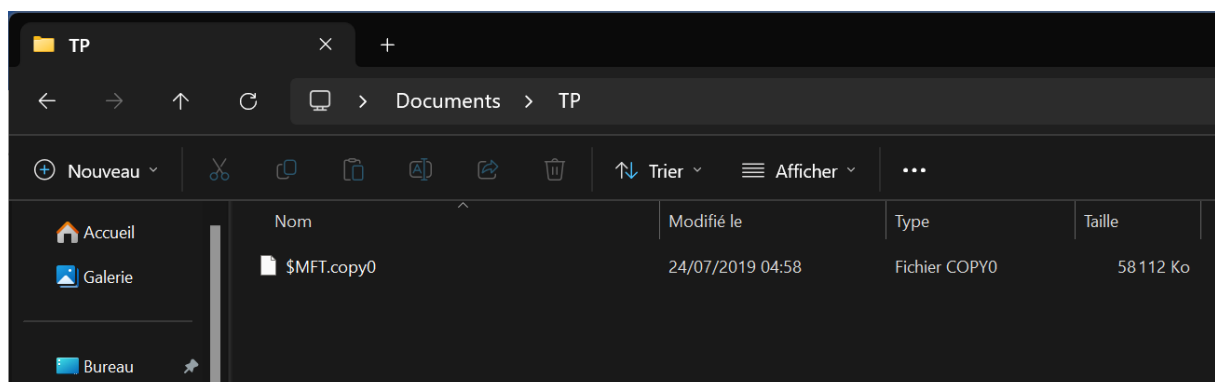
Evidence:File System[Path]... Options

Export Files...
Export File Hash List...
Add to Custom Content Image (AD1)

Ensuite sélectionner l'emplacement et cliquer sur OK :



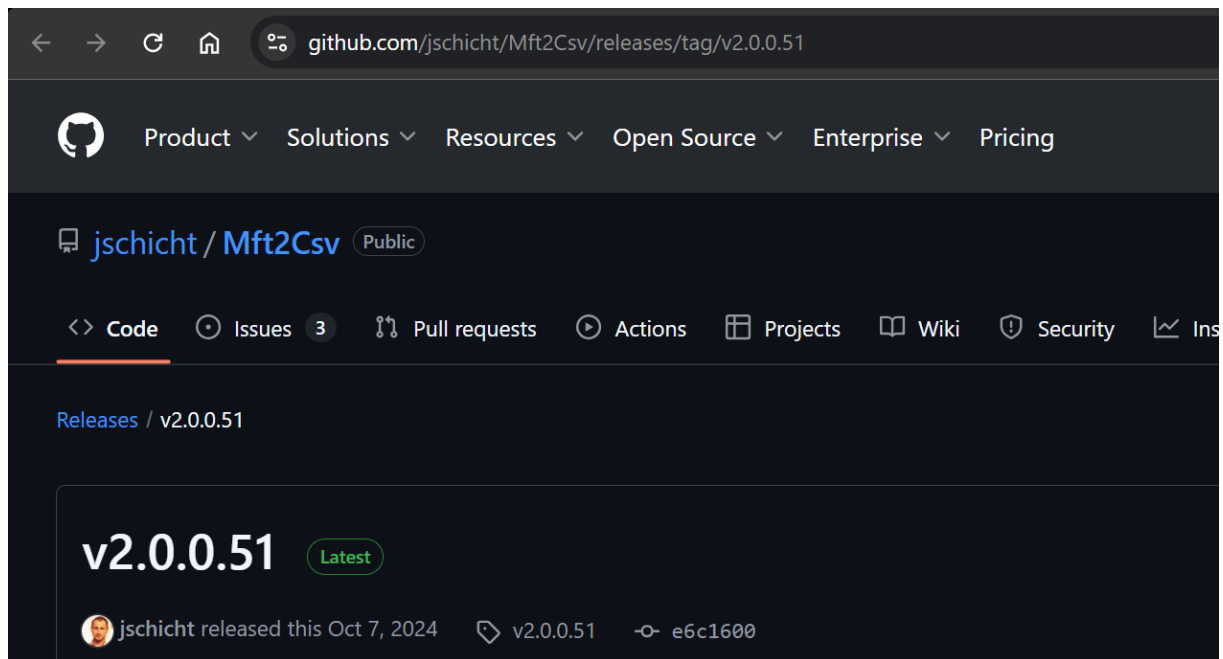
Et le fichier sera extrait avec succès dans le dossier choisi :



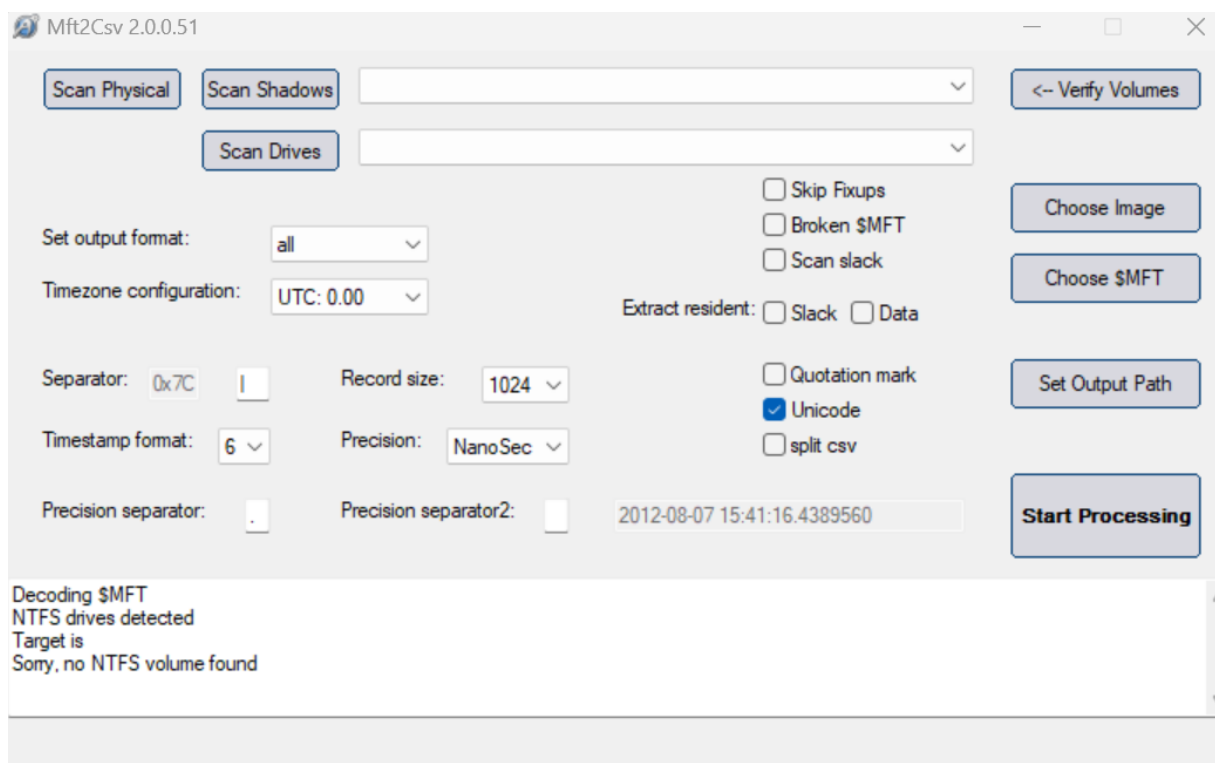
Maintenant que nous avons extrait la MFT, il ne nous reste plus qu'à exploiter ses données.

Pour pouvoir exploiter et décoder la MFT, il est possible d'utiliser l'outil **open source Mft2Csv** qui va **convertir le contenu de la MFT en fichier CSV**.

A télécharger sur <https://github.com/jschicht/Mft2Csv/releases/tag/v2.0.0.51>



Lançons l'outil :



Pour sélectionner notre fichier MFT précédemment extrait, on clique sur **Choose \$MFT** puis sur **Start Processing** :

Mft2Csv 2.0.0.51

Set output format:
 Timezone configuration:
 Extract resident: ☐ Slack ☐ Data

Separator: |
☐ Skip Fixups

Timestamp format:
☐ Broken \$MFT

Precision separator:
☐ Scan slack

☐ Quotation mark
☒ Unicode
☐ split csv

Decoding \$MFT
 NTFS drives detected
 Selected \$MFT file: C:\Users\sarrf\Documents\TP\\$MFT.copy0
 Timestamps presented in UTC: 0.00

Decoding \$MFT info and writing to csv
 First examination of MFT record 9579 of 58112 (step 1 of 3)
 Elapsed time = 4 s

Parsing finished

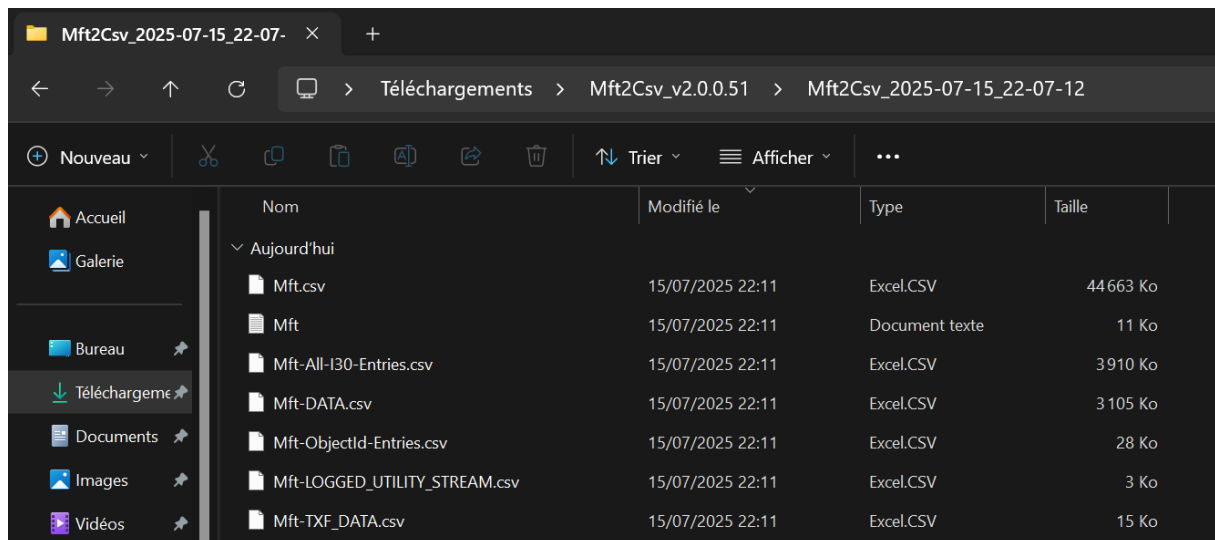
Job took:
 4 min 32 s

Output can be found in:
 C:\Users\sarrf\Downloads\Mft2Csv_v2.0.0.51\Mft2Csv_2025-07-15_22-07-12

OK

T info and writing to csv

Ensuite **MF2CSV** va ensuite décoder les contenus de la MFT et écrire les données dans un fichier CSV qui sera facilement exploitable pour générer une **timeline** :



Et voici les fichiers CSV :

RecordOffset	Signature	IntegrityCheck	Style	HEADER_MFTRecordNumber	HEADER_SequenceNo	Header_HardLinkCount	FN_ParentReferenceNo	FN_ParentSequenceNo	FN_FileName	FN_FilePath
0x00000000	GOOD	OK	0 1 1 5 5 \$MFT	59506688	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00000400	GOOD	OK	1 1 1 5 5 \$MFTMirr	4096	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00000800	GOOD	OK	2 2 1 5 5 \$LogFile	67108864	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00000C00	GOOD	OK	3 3 1 5 5 \$Volume	0	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00001000	GOOD	OK	4 4 1 5 5 \$AttrDef	2560	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00001400	GOOD	OK	5 5 1 5 5 \$Folder	815936	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00001800	GOOD	OK	6 6 1 5 5 \$Bitmap	815936	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00001C00	GOOD	OK	7 7 1 5 5 \$Boot	8192	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00002000	GOOD	OK	8 8 1 5 5 \$BadClus	0	hidden+system	hidden+system	DOS+WIN32 1 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00002400	GOOD	OK	9 9 1 5 5 \$Secure	391884	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00002800	GOOD	OK	10 10 1 5 5 \$UpCase	131072	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00002C00	GOOD	OK	11 11 1 5 5 \$Extend	0	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00003000	GOOD	OK	12 12 0 1 5 5 \$Index	0	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00003400	GOOD	OK	13 13 0 1 5 5 \$Index	0	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00003800	GOOD	OK	14 14 0 1 5 5 \$Index	0	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193

Pour voir les données en clair nous allons dans le menu "Données" → puis "Convertir" :

RecordOffset	Signature	IntegrityCheck	Style	HEADER_MFTRecordNumber	HEADER_SequenceNo	Header_HardLinkCount	FN_ParentReferenceNo	FN_ParentSequenceNo	FN_FileName	FN_FilePath
0x00000000	GOOD	OK	0 1 1 5 5 \$MFT	59506688	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193
0x00000400	GOOD	OK	1 1 1 5 5 \$MFTMirr	4096	hidden+system	hidden+system	DOS+WIN32 0 2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193	2019-07-24 04:58:21.3183193

- Ensuite on clique sur Délimité → Suivant → On coche "Tabulation" et on clique sur terminer :

MT - Excel (Echec de l'activation du produit)

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
1	RecordOffset	Signature	IntegrityCheck	Style	HEADER_MF	HEADER_Seq	Header_Harc	FN_Parent	ReFN_Parent	SeFN_FileName	FilePath	HEADER_Flag	RecordActive	FileSizeBytes	SI_FilePermit	FN_F
2	0x00000000	GOOD	OK		0	1	1	1	5	5 \$MFT	:\\$MFT	FILE	ALLOCATED	59506688	hidden+syste	hidd
3	0x00000400	GOOD	OK		1	1	1	1	5	5 \$MFTMirr	:\\$MFTMirr	FILE	ALLOCATED	4096	hidden+syste	hidd
4	0x00000800	GOOD	OK		2	2	1	1	5	5 \$LogFile	:\\$LogFile	FILE	ALLOCATED	67108864	hidden+syste	hidd
5	0x00000C00	GOOD	OK		3	3	1	1	5	5 \$Volume	:\\$Volume	FILE	ALLOCATED	0	hidden+syste	hidd
6	0x00001000	GOOD	OK		4	4	1	1	5	5 \$AttrDef	:\\$AttrDef	FILE	ALLOCATED	2560	hidden+syste	hidd
7	0x00001400	GOOD	OK		5	5	1	1	5	5 .	:\.	FOLDER	ALLOCATED		hidden+syste	hidd
8	0x00001800	GOOD	OK		6	6	1	1	5	5 \$Bitmap	:\\$Bitmap	FILE	ALLOCATED	815936	hidden+syste	hidd
9	0x00001C00	GOOD	OK		7	7	1	1	5	5 \$Boot	:\\$Boot	FILE	ALLOCATED	8192	hidden+syste	hidd
10	0x00002000	GOOD	OK		8	8	1	1	5	5 \$BadClus	:\\$BadClus	FILE	ALLOCATED	0	hidden+syste	hidd
11	0x00002400	GOOD	OK		9	9	1	1	5	5 \$Secure	:\\$Secure	FILE+INDEX	ALLOCATED	391884	hidden+syste	hidd
12	0x00002800	GOOD	OK		10	10	1	1	5	5 \$UpCase	:\\$UpCase	FILE	ALLOCATED	131072	hidden+syste	hidd
13	0x00002C00	GOOD	OK		11	11	1	1	5	5 \$Extend	:\\$Extend	FOLDER	ALLOCATED		hidden+syste	hidd



Analyse des fichiers listés

Fichiers suspects ou temporaires

- tmpA7F6.tmp, tmp4E2F.tmp, memdump.mem, driver.sys, etc.
 - Ce sont souvent des fichiers **temporaires** ou utilisés par des **malwares** pour cacher des **payloads** ou du code injecté.

Logiciels et exécutables notables

- hfvyhVOAcF.exe – Localisé dans %AppData%.
 - Le nom est **aléatoire et suspect** (typiquement utilisé par des malwares). **À analyser en priorité.**
- driver.sys – Situé dans un dossier Temp sous Desktop.
 - Un pilote système dans un dossier utilisateur est **très suspect**.
- memdump.mem – Peut indiquer une **capture mémoire** faite par un outil de forensique ou un malware.

Répertoires système légitimes

- \Windows\System32, \Windows\WinSxS
 - Fichiers comme WDF01000.sys, WDFilter.sys, etc., semblent légitimes s'ils ne sont pas modifiés.

Utilisation d'outils Windows PE ou installation

- setuperr.log, diagerr.xml
 - Liés à l'installation ou au diagnostic de Windows (souvent légitimes sauf si réutilisés).

Points d'intérêt à investiguer

1. **hfvyhVOAcF.exe dans %AppData%**
 - Nom fortement aléatoire.
 - Localisation inhabituelle.
 - Signature et comportement à vérifier avec **VirusTotal** et **hash MD5/SHA1**.
2. **driver.sys dans un dossier temporaire utilisateur**
 - Pilote système non signé ou injecté.

- Doit être comparé avec les pilotes présents dans C:\Windows\System32\drivers.

3. memdump.mem

- Peut indiquer soit une activité d'analyse forensique légitime, soit de l'exfiltration mémoire par malware.

CONCLUSION

L'investigation réalisée a permis de démontrer l'occurrence d'une attaque ciblée sur un poste utilisateur, probablement initiée par l'ouverture d'un fichier malveillant en pièce jointe d'un courriel frauduleux. Grâce à l'analyse de la mémoire vive et du disque dur, plusieurs éléments suspects ont été identifiés, notamment des processus inconnus en cours d'exécution, des fichiers exécutables au nom aléatoire dans des répertoires inhabituels (%AppData%, Temp), ainsi que des connexions réseau établies vers une adresse IP externe non autorisée.

L'analyse de la MFT (Master File Table) a également révélé la présence de fichiers potentiellement malveillants comme `driver.sys` et `hfvyhVOAcF.exe`, renforçant l'hypothèse d'une compromission active avec un mécanisme de persistance.

Ces résultats ont mis en évidence des indicateurs de compromission clairs (hashs, chemins de fichiers, adresses IP) permettant non seulement de qualifier la nature de l'incident mais aussi d'orienter les actions correctives.

Recommandations

- Isoler immédiatement la machine concernée.
- Supprimer les exécutables malveillants identifiés et nettoyer les tâches planifiées ou clés de registre persistantes.
- Mettre à jour les solutions antivirus et les signatures.
- Renforcer les procédures de sensibilisation interne sur les risques liés aux pièces jointes.
- Déployer une surveillance proactive (EDR, SIEM) pour anticiper d'éventuelles futures intrusions.

Cette investigation a démontré l'importance d'une réaction rapide et structurée face à une cyberattaque. La mise en place d'outils forensics adaptés et d'une méthodologie rigoureuse a permis de reconstituer les faits, collecter les preuves et formuler des recommandations concrètes pour protéger l'infrastructure de l'entreprise.